2024년도 컨설팅감사

컨설팅감사 결과보고서

- IT개인정보처리시스템 적정성 점검 -

2024. 12.

한국산업기술기획평가원

감 사 단

목 차

Ⅰ. 감사실시 개요 ····· 1

1. 감사배경 및 목적 ····· 1

2. 감사대상 및 범위 ····· 1

3. 감사기간 및 인원 ····· 2

4. 감사실시 과정 ····· 2

5. 감사 중점사항 ····· 4

Ⅱ. 감사결과 ····· 5

1. 총평 ····· 5

2. 지적사항 총괄 ····· 5

3. 지적사항 요약 ····· 5

Ⅲ. 지적사항에 대한 처분요구 ····· 9

1. 처분요구사항 일람표 ····· 9

2. 현지조치 일람표 ····· 10

3. 모범사례 일람표 ····· 11

첨부. 감사결과 처분요구서 ····· 12

Ⅰ. 감사실시 개요

1. 감사배경 및 목적

한국산업기술기획평가원(이하 “기획평가원”이라 한다)은 기관 소개, 국가연구개발사업 평가·관리 등을 위하여 기획평가원 홈페이지, 범부처 연구비통합관리시스템(RCMS), 디지털평가시스템(Stella) 등의 시스템을 운영하고 있다. 동 시스템의 경우 기관 홈페이지 회원, 국가연구개발사업 과제 수행자의 성명, 연락처 등 개인정보를 보관 및 처리하고 있으므로 ‘IT개인정보처리시스템[1)]’ 이라고 볼 수 있다. 따라서, 기획평가원은 ‘IT개인정보처리시스템’에서 관리중인 개인정보의 유출, 위조·변조 또는 훼손 등이 되지 않도록 안전하게 관리해야 한다.

본 감사에서는 ‘IT개인정보처리시스템’에 대한 안전성 확보에 필요한 기술적·관리적 및 물리적 조치 등 개인정보보호 관점에서 점검하여 문제점을 도출하고 개선방안을 제시하여 ‘IT개인정보처리시스템’의 개인정보보호 활동 업무가 기획평가원의 주요업무로써 효율적으로 체화되도록 감사를 실시하였다.

2. 감사대상 및 범위

감사대상은 ‘IT개인정보처리시스템’을 운영 및 관리하는 □■□■□■■(□■□△▲△, ◆□■☆★☆▼▲□, ◎◇◆□■) 및 사업부서로 IT시스템 운영 및 활용에 대한 적정성을 조사하였다.

1) 데이터베이스 시스템 등 개인정보를 처리할 수 있도록 체계적으로 구성한 응용시스템

3. 감사기간 및 인원

본 감사는 2024. 8. 12.부터 같은 해 8. 23.까지 IT 및 개인정보보호 컨설팅 전문기관과의 사전점검을 실시하고, 2024. 10. 17.부터 같은 해 10. 23.까지 5일간 예비조사 기간을 거쳐 나타난 문제점 및 개선 필요 사항을 토대로 감사반장 1명, 감사인 10명(준감사인 1명, 교차감사인 5명 포함)등 총 11명을 투입하여 2024. 10. 30.부터 같은 해 11. 6.까지 6일간 실지감사를 실시하였다. 감사결과는 내·외부 감사인 검토과정을 거쳐, 2024. 12. xx. 상임감사가 최종 확정하였다.

4. 감사실시 과정

이번 감사는 기획평가원 'IT개인정보처리시스템'의 적정성 점검을 위하여 다음의 절차로 진행하였다.

가. 사전조사

효과적이고 효율적인 감사 수행을 위하여 감사 관련 개인정보보호 컨설팅 전문기관과 공동으로 사전점검을 실시하였고 감사대상 부서인 □■□■□■■ 본부장, 실장 및 담당자를 대상으로 간담회를 개최하여 감사 추진 방향 및 주요 감사착안사항(안)을 설명하고, 감사대상 부서의 의견을 청취하였다.

나. 예비조사

2024. 10. 17.부터 같은 해 10. 23.까지의 예비조사를 통하여 감사인 별 중점 추진방향을 설정하고, 실지감사를 위한 관련 증빙 수집, 감사대상

및 대상자와 감사범위에 대해 논의하였으며, 감사인 별로 제척·회피 자가진단을 실시하였다.

다. 실지감사

착안사항 발굴 회의와 예비조사를 거쳐 2024 10. 30.부터 같은 해 11. 6.까지 6일간 감사인원 11명(준감사인 1명, 교차감사인 5명 포함)을 투입하여 감사 중점사항을 토대로 실지감사를 실시하였다.

라. 마감회의 및 내부변호인 제도 안내

감사 종료 후에는 조치요구사항과 관련되는 부서를 대상으로 실지감사 마감회의(강평)를 통해 특정감사 결과에 대한 개략적인 평가와 주요 문제점, 개별적인 지적사항 등을 설명하고, 업무상의 애로 및 건의사항을 청취하여 감사 수용도 제고를 위해 노력하였다.

마. 윤리자가진단 및 제3자 검증 시행

감사 종료 후, 감사인은 윤리 자가진단을 실시하였으며, 감사에 참여하지 않은 감사인(제3자)이 피감부서장 및 피감인에게 접촉하여 감사활동 중 감사인의 비위행위 등 윤리준수 적절성을 검토 후 제3자 검증 의견서를 작성하는 등 개별감사에 대한 감사인의 객관성 및 윤리기준을 강화코자 노력하였다.

바. 감사실무위원회

감사결과를 보다 합리적이고 공정하게 처리하기 위하여 감사실장을 위원장으로 하여 감사반 및 감사부서 직원이 참석하여 감사처분요구서 초안에 대한 검토를 진행하였다.

사. 감사심의위원회

감사심의위원회를 개최하여 처분요구(안)에 대해 내·외부감사인 검토를 진행하고, 제3자 검증의 적절성을 검토하였다.

5. 감사 중점사항

이번 컨설팅감사는 'IT개인정보처리시스템'의 적정성 및 적법성을 검증하고 문제점에 대한 단순 지적보다는 컨설팅이나 개선방안을 제시하는데 중점을 두었으며, 내부통제 위험요소에 기반하여 [표 1]와 같이 사전조사 및 예비조사 기간 동안 검토한 주요 점검사항에 대해 선택과 집중을 통한 효율적, 전략적 감사를 위해 노력하였다. 또한, 감사규정 및 감사원의 자체감사 통합매뉴얼 준수 등을 통해 원칙과 객관성을 확보하여 공정한 감사가 될 수 있도록 역량을 집중하였다.

[표 1] 감사 중점 추진사항

연번	중점 추진방향	
	분야	점검분야
1	개인정보 관련 규정	· 관련 내규(정보보안규칙, 개인정보보호지침 등)의 개인정보보호법 및 동법 시행령 반영 · 운영의 적정성 여부
2	개인정보 처리	· 개인정보 수집·이용 동의 관련 점검 · 주요 IT개인정보처리시스템*에 대한 개인정보보호 관리 실태 점검 * KEIT 통합고객정보관리시스템(CIMS), 기관 홈페이지(www.keit.re.kr), 범부처 연구비통합관리시스템(www.rcms.go.kr), 디지털평가시스템(stella.keit.re.kr),
3	IT개인 정보처리 시스템 취약점 점검	· IT개인정보처리시스템 취약점 점검 및 리스크 분석* * 과학기술정보통신부, 한국인터넷진흥원 "주요정보통신기반 시설 기술적 취약점 분석·평가 방법 상세 가이드(2021.03)" 에서 지정한 기준으로 실시
4	모범사례 발굴	

Ⅱ. 감사결과

1. 총평

'IT개인정보처리시스템' 내 개인정보보호 관련 전반에 대한 점검을 통하여 업무 적정성을 확인하고 개선점을 발굴하여 이를 개선토록 요구함으로써 기획평가원의 내부통제 체계를 공고히 함

2. 지적사항 총괄

(단위: 건, 백만원)

합계			변상 (금액)	징계 (인원)	시정(금액)				주의 경고 (인원)	주의 (인원)	개선	권고	통보	고발 (인원)	현지 조치	모범 사례 (인원)
총 건수	신분상 조치인원	재정상 조치금액			소계	추징	감액	기타								
14	1	-	-	-	- (-)	-	-	- (-)	-	1	3	-	5	-	2	3 (3)

3. 지적사항 요약

【처분요구사항】

1) 「개인정보 보호법」의 '자동화된 결정에 대한 조치 기준' 관련 「개인정보보호지침」 반영 필요

「개인정보 보호법」 및 동법 시행령에서 제시된 자동화된 결정에 대한 정보주체의 권리 및 조치 등에 대해 「개인정보 보호지침」에 반영이 필요하다. (개선 1건)

2) 통합고객정보관리시스템(CIMS) 개인정보 수집·이용 동의 업무 미흡

통합고객정보관리시스템(CIMS) 회원 가입 및 관리 업무 관련 개인정보 처리 및 보호 기준상 개선이 필요한 부분에 대해서 개선방안 마련이 필요하다. (통보 1건)

3) IT개인정보처리시스템 기술적 보호조치 미흡

IT개인정보처리시스템(KEIT 홈페이지, 디지털평가시스템(Stella), 범부처연구비통합관리시스템(RCMS), 통합고객정보관리시스템(CIMS))에 대한 개인정보의 안전성 점검 결과 개선이 필요한 “접근 권한의 관리”, “접속기록의 보관 및 점검” 등 취약점에 대해 개선방안 마련이 필요하다. (통보 2건, 개선 1건)

4) IT개인정보처리시스템의 개인정보 안정성 확보 조치 미흡

IT개인정보처리시스템에 대한 Web 취약점 분석·평가 결과 개선이 필요한, “프로세스 검증 누락”, “파일업로드” 등 취약점에 대해 개선방안 마련이 필요하다. (통보 2건, 개선 1건)

5) 개인정보 처리 업무 부적정

사업 공고 업무를 처리하는 과정에서 이름과 소속기관 정보가 포함된 붙임자료를 첨부하여 개인정보를 유출한 관련자에게 재발방지를 위해 주의를 촉구합니다. (주의 1명)

【현지조치사항】

1) 통합고객정보관리시스템(CIMS) 개인정보 수집·이용 동의 업무 미흡

통합고객정보관리시스템(CIMS)를 통한 회원 가입시 안내하는 “이용약관” 제4조(이용계약의 성립)에 대해「개인정보 보호법」에서 제시하는 용어 및 서비스 범위 등 안내를 명확히 하도록 조치하였다. (현지조치 1건)

2) IT개인정보처리시스템 기술적 보호조치 미흡

범부처 연구비통합관리시스템(RCMS) 시스템관리자 페이지에서의 접근권한 말소 또는 삭제시 로그가 기록 되도록 기능 개선 조치를 하였다. (현지조치 1건)

【모범사례】

1) 퇴직자 개인정보관리체계 개선을 통한 보안성 및 업무 효율성 강화에 기여

관련자는 임직원이 퇴직할 경우 즉각적인 권한회수와 개인정보 관리업무가 차질 없이 이루어질 수 있도록 기존 시스템 별로 관리하던 개인정보를 통합고객정보관리시스템(CIMS)으로 관리체계를 일원화하였다. 또한 퇴직자 권한 자동 회수 기능을 구축하여 불필요한 개인정보 중복 저장·관리 제거 및 누락없는 퇴직자 권한 회수를 통해 기술적, 인적 보안 사고를 미연에 방지하고, 퇴직 발생 시마다 담당자가 직접 수행하던 퇴직자 권한 회수 업무를 데이터 기반으로 자동화하여 업무 효율과 생산성을 향상에 기여하였다.

2) “개인정보 내부관리 계획” 수립, 이행 및 전파를 통한 개인정보보호 강화에 기여

관련자는 적극적인 업무자세로 충실한 개인정보 내부 관리계획 수립 및 전 직원이 쉽게 이해하고 이행 및 확인할 수 있도록 관련 매뉴얼, 절차서 등을 제작하고 “개인정보 내부관리 계획”에 따른 이행 결과에 대해 적정성 검토를 통해 리스크별 통제방안 도출 및 제도개선 등을 추진하여 원내 개인정보보호에 대한 인식 제고에 기여하였다.

3) 범부처 연구비통합관리시스템(RCMS) 사용자 개인정보보호 등에 기여

관련자는 적극적인 업무자세로 과기부 고시「국가연구개발정보처리기준」에 의거 연구 활동비 부가 정보를 내부 회계시스템과 RCMS에 이중으로 등록해야 하는데 이를 국가연구자번호를 필수로 하되 성명, 소속 등 개인 민감 정보는 보수적으로 수집될 수 있도록 기능을 개선하여 연구편의를 도모함과 동시에 개인정보보호에 기여하였다. 또한 정산담당자의 애로 사항인 연구개발비 이월금을 세목 간 전용이 불가능하였던 것을 전용 가능 기능을 추가하여 연구수행자의 편의성을 높이는 등 「국가연구개발혁신법」에 근거하여 전 부처의 연구비 관리행정 기준에 맞추어 일원화함으로써 고객 만족도 제고에도 기여하였다.

Ⅲ. 지적사항에 대한 처분요구

1. 처분요구사항 일람표

지 적 사 항	순번	조 치 요 구 사 항	조치 구분	처분 요구일	조치 기한일	처리부서
「개인정보 보호법」의 ‘자동화된 결정에 대한 조치 기준’ 관련 「개인정보보호 지침」 반영 필요	1	ㅇ개인정보 보호법」 및 동법 시행령에서 제시된 자동화된 결정에 대한 정보주체의 권리 및 조치 등에 대해 「개인정보 보호지침」에 반영	개선	2024. 12.	2025. 2. (2개월)	◎◇◆□■
통합고객정보관리 시스템(CIMS) 개인정보 수집·이용 동의 업무 미흡	1	ㅇ 통 합 고 객 정 보 관 리 시 스 템 (CIMS) 회원 가입, 관리 업무 관련 개인정보 처리 및 보호 기준상 개선이 필요한 부분에 대해서 개선방안 마련	통보	2024. 12.	2025. 2. (2개월)	◎◇◆□■
IT개인정보처리 시스템 기술적 보호조치 미흡	1	ㅇKEIT 홈페이지에 대한 개인정보의 안전성 점검 결과, “접근 권한의 관리”, “개인정보의 암호화” 등 취약점에 대해 개선방안 마련	통보	2024. 12.	2025. 2. (2개월)	□■□△▲△
	2	ㅇ디지털평가시스템(Stella) 및 범부처 연구비통합관리시스템(RCMS)에 대한 개인정보의 안전성 점검 결과, “접속기록의 보관 및 점검”, “개인정보의 암호화” 등 취약점에 대해 개선방안 마련	통보	2024. 12.	2025. 2. (2개월)	◆□■☆★☆▼▲□
	3	ㅇ 통 합 고 객 정 보 관 리 시 스 템 (CIMS)에 대한 개인정보의 안전성 점검 결과, “개인정보의 파기”, “접근 권한의 관리” 등 취약점에 대해 개선	개선	2024. 12.	2025. 2. (2개월)	◎◇◆□■

지 적 사 항	순번	조 치 요 구 사 항	조치 구분	처분 요구일	조치 기한일	처리부서
IT개인정보처리 시스템의 개인정보 안정성 확보 조치 미흡	1	ㅇ기관 홈페이지에 대한 Web 취약점 분석·평가 결과, “불충분한 인증”, “파일업로드” 등 취약점에 대해 개선방안 마련	통보	2024. 12.	2025. 2. (2개월)	□■□△▲△
	2	ㅇ디지털평가시스템(Stella) 및 통합연구비관리시스템(RCMS)에 대한 Web 취약점 분석·평가 결과, “프로세스 검증 누락”, “파일업로드” 등 취약점에 대해 개선방안 마련	통보	2024. 12.	2025. 2. (2개월)	◆□■☆★☆▼▲□
	3	ㅇ통합고객정보관리시스템(CIMS)에 대한 Web 취약점 분석·평가 결과, “불충분한 세션 만료” 등 취약점에 대해 개선	개선	2024. 12.	2025. 2. (2개월)	◎◇◆□■
개인정보 처리 업무 부적정	1	ㅇ사업 공고 업무를 처리하는 과정에서 이름과 소속기관 정보가 포함된 붙임자료를 첨부하여 개인정보를 유출한 관련자에게 재발방지를 위해 주의를 촉구	주의	2024. 12.	-	○■▼▽■

2. 현지조치사항 일람표

지 적 사 항	순번	조 치 요 구 사 항	조치 구분	처리부서
통합고객정보관리 시스템(CIMS) 개인정보 수집·이용 동의 업무 미흡	1	ㅇ통합고객정보관리시스템(CIMS)를 통한 회원 가입시 안내하는 “이용약관” 제4조(이용계약의 성립)에 대해「개인정보 보호법」에서 제시하는 용어 및 서비스 범위 등 안내를 명확히 하도록 조치	현지조치	◎◇◆□■
IT개인정보처리 시스템 기술적 보호조치 미흡	2	ㅇ범부처 연구비통합관리시스템(RCMS) 시스템 관리자 페이지에서의 접근권한 말소 또는 삭제시 로그가 기록 되도록 기능 개선 조치	현지조치	◆□■☆★☆▼▲□

3.모범사례 일람표

제목	순번	관계부서	성명	공적요약	기대효과
퇴직자 개인정보관리체계 개선을 통한 보안성 및 업무 효율성 강화에 기여	1	□■□△▲△	◎▼■	ㅇ임직원이 퇴직할 경우 즉각적인 권한회수와 개인정보 관리업무가 차질 없이 이루어질 수 있도록 기존 시스템 별로 관리하던 개인정보를 통합고객정보관리시스템(CIMS)으로 관리체계 일원화 및 퇴직자 권한 자동 회수 기능 구축	ㅇ기술적, 인적 보안 사고 방지 및 업무 효율과 생산성 향상에 기여
"개인정보 내부관리 계획" 수립, 이행 및 전파를 통한 개인정보보호 강화에 기여	2	◎◇◆□■	◇▼★	ㅇ적극적인 업무자세로 충실한 개인정보 내부 관리계획 수립 및 전 직원이 쉽게 이해하고 이행, 확인할 수 있도록 관련 매뉴얼, 절차서 등을 제작하고 이행 결과에 대해 적정성 검토를 통해 리스크별 통제방안 도출, 제도개선 등을 추진	ㅇ원내 임직원 및 용역수행자 대상 개인정보보호에 대한 인식 제고에 기여
범부처 연구비통합관리 시스템(RCMS) 사용자 개인정보보호 등에 기여	3	◆□■☆★☆▼▲□	☆□△	ㅇ적극적인 업무자세로 RCMS상 연구활동비 부가정보 입력시 개인정보 입력을 최소화하고 직접비 이월금의 세목 간 전용 가능 기능 추가 등 연구수행자의 편의성을 제고	ㅇ연구수행자에게 연구편의를 도모함과 동시에 개인정보 보호에 기여

[첨부] 감사결과 처분요구(안)

일련번호	1	감사자	□★☆, ●▼□ (교차감사)	공개(○), 비공개(　)	
신분상 조치인원	-	재정상 조치방법	-	재정상 조치금액	-
수감부서 (처리할 부서)	□■□■□■■(◎◇◆□■)	처분요구일	2024.12.	회신 기한일	2025.02.

개　선

제　　목　‘「개인정보 보호법」의 ‘자동화된 결정에 대한 조치 기준’ 관련 「개인정보보호지침」 반영 필요

관 계 부 서　□■□■□■■(◎◇◆□■)

조 치 부 서　□■□■□■■(◎◇◆□■)

내　　용

1. 업무 개요

한국산업기술기획평가원(이하 ‘기획평가원’이라 함)은 개인정보보호를 위하여 「개인정보 보호지침」을 제정하여 개인정보의 처리에 관한 기준, 개인정보 침해유형 및 예방조치, 안정성 확보보치 기준 등에 관한 세부적인 사항을 규정하고 매년 개인정보보호 내부관리계획 수립 및 이행을 통하여 개인정보보호 업무를 수행하고 있다.

2. 관련 법령 및 판단기준

인공지능(AI) 등 사람의 개입 없이 이루지는 '자동화된 결정'[2]에 대해 [표 2]과 같이 정보주체가 설명 또는 검토 요구를 할 수 있도록 하고, 정보주체인 국민의 권리 또는 의무에 중대한 영향을 미치는 경우에는 거부할 수 있도록 하는 근거가「개인정보 보호법」에 반영되어 개정('23. 3. 14)되었고, 개정 조문의 시행 관련하여 동법 시행령에도 반영되어 시행('24. 3. 15) 되고 있다.

따라서, 기획평가원의 연구개발사업 평가 ·관리 및 채용 등 업무에 '자동화된 결정'에 활용된 분야가 있으면 관련 「개인정보 보호법」 및 동법 시행령을 준수하여야 한다.

[표 2] '자동화된 결정' 관련 「개인정보 보호법」 내용(요약)

구분		내용(요약)
법률	제37조의2 (자동화된 결정에 대한 정부주체의 권리등)	o 정보주체는 완전히 자동화된 시스템으로 개인정보를 처리하여 이루어지는 결정이 자신의 권리 또는 의무에 중대한 영향을 미치는 경우에는 해당 개인정보처리자*에 대하여 해당 결정을 거부할 수 있는 권리를 가짐. o 정보주체는 개인정보처리자*가 자동화된 결정을 한 경우에는 그 결정에 대하여 설명 등을 요구할 수 있음. o 개인정보처리자*는 정보주체가 자동화된 결정을 거부하거나 이에 대한 설명 등을 요구한 경우에는 정당한 사유가 없는 한 자동화된 결정을 적용하지 아니하거나 인적 개입에 의한 재처리·설명 등 필요한 조치를 하여야 함. o 개인정보처리자*는 자동화된 결정의 기준과 절차, 개인정보가 처리되는 방식 등을 정보주체가 쉽게 확인할 수 있도록 공개하여야 함. * 업무를 목적으로 개인정보를 처리하는 공공기관, 법인, 단체 및 개인 등(예:기획평가원)
시행령	제44조의2(자동화된 결정에 대한 거부 및 설명 등 요구의 방법 및 절차)	
	제44조의3(거부·설명등 요구에 따른 조치)	
	제44조의4(자동화된 결정의 기준과 절차 등의 공개)	

2) 사람의 개입 없이 완전히 자동화된 시스템으로, 개인정보를 분석하는 등 처리하는 과정을 거쳐, 개인정보처리자가 정보주체의 권리 또는 의무에 영향을 미치는 최종적인 결정을 한 경우

3. 감사결과 확인된 사항

기획평가원 업무 중 개인정보 관련 인공지능(AI) 등을 활용한 자동화 기능을 도입한 사례는 “채용시 자기소개서 내 블라인드 위배(인적사항 노출)[3] 사항 심사”, “연구개발과제 평가 관련 평가위원 자동선정” 및 “RCMS[4]를 통해 연구비를 사용하는 연구개발기관에 연구비 사용내역과 연관된 불인정 사례 등을 비교하여 불인정 가능성 있을 경우 자동 통보” 등이 있는 것으로 조사 되었다.

상기 3가지 사항에 대해서 「개인정보 보호법」에서 제시하고 있는 ‘자동화된 결정’ 해당 여부에 조사한 결과, [표 3]와 같이 해당하지 않는 것으로 확인 되었다.

[표 3] 자동화 기능을 도입한 업무의 ‘자동화된 결정’ 해당 여부

구 분		자동화된 결정	
		검토결과	여부
채용	채용시 자기소개서 내 블라인드 위배(인적사항 노출) 사항 심사	o 인공지능(AI)를 활용하여 자기소개서내 블라인드 위배사항을 자동 검출하고 있으나, 검출 결과에 대하여 내부전문인력(용역사 및 인사담당자) 추가 검토 및 서류 결과 평가위원회에서 동 결과를 확인 후 최종 확정하고 있어 인공지능(AI)를 활용한 결과가 정보주체의 최종적인 결정이 아님.	미해당
평가	연구개발과제 평가시 평가위원 자동선정	o 평가 전문성 및 공정성 제고를 위해 전자평가시스템을 통한 평가위원 자동추천 - 평가 담당자는 평가위원 후보풀에서 산업기술분류 및 키워드 유사도 기반 하에 원하는 비율·인원 입력시 시스템에서 자동적으로 평가위원 후보 추천 o 추천된 후보 평가위원에 대해 평가 담당자가 연락 등을 통하여 최종적으로 평가위원을 선정하므로 평가위원 자동추천 결과가 정보주체의 최종적인 결정이 아님.	미해당

3) 성명 출신지역, 가족관계, 학력(학교명), 성별, 생년월일 등 인적사항 노출 등

4) 연구개발사업 예산을 실시간으로 투명하게 관리하기 위한 범부처 연구비통합관리시스템으로 수행기관에서 연구비 사용내역을 증빙하여 전문기관에서 실시간으로 관련 비용 지급 등 연구비 지급, 관리 및 정산 기능 등을 제공

구 분		‘자동화된 결정’	
		검토결과	여부
정산	RCMS를 통해 연구개발기관에 연구비 사용내역과 연관된 불인정 사례를 비교하여 불인정 가능성 있을 경우 자동 통보	o RCMS시스템에서 개인정보(인건비 계상률 과다 점검 등)등을 처리하여 연구비 불인정 가능성을 통보하는 것으로 사람의 개입 없는 자동화된 시스템으로 보이나, o 이러한 연구비 불인정 가능성 통보는 회계법인 정산을 통한 최종 연구비 불인정 결정을 하기 전 단계에서 해당 연구비 집행기관에게 불인정에 대한 위험성을 미리 알려 보완할 수 있게 하는 것으로 해당 결정이 정보주체인 기관에 대한 최종적인 결정이 아님.	미해당

다만, 인공지능(AI)등 기술의 발전 속도가 빠르고 세계적으로도 인공지능(AI)등을 활용한 자동화 기술의 업무 도입 및 활용 추세가 빠르게 증가하는 만큼 기획평가원 「개인정보 보호지침」에 ‘자동화된 결정’ 관련 내용을 반영하여 전 직원이 관련 지침을 준수하도록 할 필요가 있다.

관계부서 의견

개인정보보호 업무를 총괄하는 ◎◇◆□■은 감사결과를 전반적으로 수용하면서 ‘자동화된 결정’ 분야가 향후 연구개발사업 평가·관리 및 채용 분야에 적용될 수 있는 만큼 「개인정보보호지침」에 반영하겠다는 의견을 제시하였다.

조치할 사항

□■□■□■■(◎◇◆□■)은 「개인정보 보호법」 및 동법 시행령에서 제시된 자동화된 결정에 대한 정보주체의 권리 및 조치 등을 「개인정보 보호지침」에 반영하여 주시기 바랍니다. **【개선】**

일련번호	2	감사자	□★☆, ▽□□	공개(○), 비공개(　)	
신분상 조치인원	-	재정상 조치방법	-	재정상 조치금액	-
수감부서 (처리할 부서)	□■□■□■■(◎◇◆□■)	처분요구일	2024.12.	회신 기한일	2025.02.

통 보 · 현지시정

제　　목　통합고객정보관리시스템(CIMS) 개인정보 수집·이용 동의 업무 미흡

관 계 부 서　□■□■□■■(◎◇◆□■)

조 치 부 서　□■□■□■■(◎◇◆□■)

내　　용

1. 업무 개요

한국산업기술기획평가원(이하 '기획평가원'이라 함)은 기관 소개, 국가연구개발사업 평가·관리 등을 위하여 KEIT 홈페이지[5], 디지털평가시스템(Stella)[6], 범부처 연구비통합관리시스템(RCMS)[7] 등의 IT시스템을 운영하고 있으며 동 시스템의 효율적인 회원 가입 및 관리를 위하여 SSO(Single Sign-On, 통합인증체계) 방식[8]의 통합고객정보관리시스템(CIMS)을 운영하고 있다.

5) 기관 소개, R&D사업 안내, 정보공개, 고객 제안 및 부패·갑질 신고 접수 등을 위한 시스템
6) 국가연구개발사업 등 과제평가지원시스템
7) 국가연구개발사업 등 연구비 집행(지급, 정산 등) 관리 시스템
8) 사용자는 한 번의 회원가입으로 KEIT 홈페이지, 디지털평가시스템(Stella), 범부처 연구비통합관리시스템(RCMS) 등 기획평가원에서 서비스하는 시스템을 이용할 수 있는 통합 로그인 솔루션

2. 관련 법령(규정) 및 판단기준

기획평가원 통합고객정보관리시스템(CIMS)을 통한 회원 가입 및 관리 업무 수행시 「개인정보 보호법」 제15조(개인정보의 수집·이용), 제16조(개인정보의 수집 제한), 제17조(개인정보의 제공), 제22조(동의를 받는 방법), 제23조(민감정보의 처리 제한) 및 제24조(고유식별정보의 처리 제한) 등에서 제시하는 개인정보 처리 및 보호 기준을 준수하여야 한다.

3. 감사결과 확인된 사항

통합고객정보관리시스템(CIMS)을 통한 회원 가입 및 관리 업무에 대하여 사전조사 기간인 2024. 8. 12. 부터 같은해 8. 23. 동안 외부 개인정보보호 전문기관과 공동으로 [표 4]과 같이 「개인정보 보호법」에서 제시하고 있는 개인정보 처리 및 보호 기준을 마련하고 담당자 인터뷰 및 실지조사 등의 방법으로 점검을 실시하였다.

[표 4] 개인정보 처리 및 보호 관련 점검 분야 및 기준

분야	점검 기준	법 조항
개인정보의 수집·이용·제공	개인정보 보호법 제15조 제1항 중 해당하는 내용을 준수하여 수집·이용 여부 및 제3자 제공의 경우는 제17조제1항의 사항을 준수하는지 확인	제15조, 제17조
개인정보의 수집 제한	수집하는 항목이 개인정보 보호법 제16조를 준수하여 최소한의 개인정보가 수집되는지 여부를 확인	제16조
개인정보의 처리 제한	수집하는 항목 중 민감정보 또는 고유식별정보가 포함되어 있는지 여부를 확인하고, 법 제23조, 제24조, 제24조의2를 준수하는지 여부 확인	제23조, 제24조
개인정보의 동의 절차	개인정보의 수집·이용·제공 관련 동의를 받을 경우, 법 제15조 제2항 및 제17조 제2항의 동의 안내 사항이 적정한지 확인하고, 법 제22조제1항 및 제2항을 준수하는지 여부 확인	제15조 제17조 제22조

점검 결과, 통합고객정보관리시스템(CIMS)의 회원 가입 및 관리 업무 관련 4개 사항에 대한 개선이 필요한 것으로 조사 되었다.

가. 개인정보의 수집·이용·제공 등 안내

통합고객정보관리시스템(CIMS)를 통한 회원 가입시 안내하는 “이용약관”의 경우 「개인정보 보호법」에서 제시하는 용어를 사용해야하고 서비스 범위 등의 안내를 명확히 할 필요가 있어, [그림 1]과 같이 “이용약관” 제4조(이용계약의 성립)를 개선하여 안내할 필요가 있다.

[그림 1] “회원 이용 약관”내 제4조(이용계약의 성립) 개선(안)

[현재]

제 4 조 (이용계약의 성립)
① 이용계약은 이용자가 본 약관 내용에 대한 동의와 이용신청에 대하여 기획평가원의 이용승낙으로 성립합니다.
② 본 이용약관에 대한 동의는 이용신청 당시 해당 기획평가원 웹의 '동의함' 을 선택함으로써 의사표시를 합니다.
③ 이용고객이 이 약관에 따라 서비스 이용을 신청을 하는 것은 기획평가원이 제정한 “개인처리방침”, "저작권정책" 등 각종 정책에 대해 동의한 것으로 간주됩니다. (“개인처리방침”, "저작권정책"에 관한 자세한 내용은 기획평가원 홈페이지에서 확인하시기 바랍니다).

[개선(안)]

제 4 조 (이용계약의 성립)
① 이용계약은 이용자가 본 약관 내용에 대한 동의와 이용신청에 대하여 기획평가원의 이용승낙으로 성립합니다.
② 본 이용약관에 대한 동의는 이용신청 당시 해당 기획평가원 웹의 '동의함' 을 선택함으로써 의사표시를 합니다.
③ 이용고객이 이 약관에 따라 서비스 이용을 신청을 하는 것은 기획평가원이 제정한 "저작권정책" 등 각종 정책에 대해 동의한 것으로 간주됩니다. ("저작권정책"에 관한 자세한 내용은 기획평가원 홈페이지에서 확인하시기 바랍니다).
④ 기획평가원은 관계법령이 정하는 바에 따라 이용자 등록정보를 포함한 이용자의 개인정보를 보호하기 위해 노력합니다.
⑤ 이용자의 개인정보보호에 관한 사항은 관련법령 및 기획평가원이 정하는 “개인정보 처리방침”에 정하는 바에 따릅니다. 단, 기획평가원이 운영하는 웹페이지에 포함된 링크 또는 배너를 클릭하여 기획평가원에서 운영하지 않는 다른 사이트로 옮겨갈 경우 기획평가원의 “개인정보 처리방침”이 적용되지 않습니다.
⑥ 기획평가원의 회원 정보는 다음과 같이 수집, 이용·제공, 관리, 보호됩니다.
(1) 개인정보의 수집 : 기획평가원은 회원가입 시 회원이 제공하는 정보를 통하여 회원의 정보를 수집합니다. 또한, 이용자의 별도 동의나 법령의 근거 없이 외국인등록번호 등 고유식별정보를 수집·보관하지 않습니다.

(2) 개인정보의 이용·제공 : 기획평가원이 운영하는 웹페이지(제1조제2항에 작성된 시스템)에서 제공되는 서비스 중 동의한 웹페이지에 한해 회원정보를 목적내에서 이용하고 다른 목적으로는 이용하지 않습니다. 또한, 관계법령에 근거하여 국가기관의 요구 또는 기타 관계법령에서 정한 절차에 따른 요청이 있는 경우를 제외하고 기획평가원 서비스 제공과 관련하여 수집된 회원의 신상정보를 본인의 승낙 없이 제3자에게 누설, 배포하지 않습니다.
(3) 개인정보의 관리 : 회원은 개인정보의 보호 및 관리를 위하여 수시로 회원의 개인정보를 수정/삭제할 수 있습니다. 수신되는 정보 중 불필요하다고 생각되는 부분도 변경/조정할 수 있습니다.
(4) 개인정보의 보호 : 회원의 개인정보는 오직 회원만이 열람/수정/삭제 할 수 있으며, 이는 전적으로 회원의 이용자ID와 비밀번호에 의해 관리되고 있습니다. 따라서 타인에게 회원의 이용자ID와 비밀번호를 알려주어서는 안되며, 작업 종료 시에는 반드시 로그아웃 하고, 웹 브라우저의 창을 닫아야 합니다.(이는 타인과 컴퓨터를 공유하는 인터넷 카페나 도서관 같은 공공장소에서 컴퓨터를 사용하는 경우에 회원의 정보보호를 위하여 필요한 사항입니다)

나. 개인정보의 이용·제공

기획평가원 회원 가입시 [그림 2] 같이 “제3자 제공 및 활용 동의” 관련하여 동의를 해야만 회원가입을 할 수 있도록 구현되어 있고, 시스템 가입에서도 ITECH(산업기술R&D정보포털)[9]를 기본(Default)으로 가입하도록 의무화하고 있다. 그러나 「개인정보 보호법」제16조 제3항[10] 및 제17조 제1항[11]에 의하며 개인정보의 수집 및 제3자 제공의 경우 정보주체의 동의를 받아야 하며 개인정보 수집의 경우 그 목적에 필요한 최소한 개인정보를 수집해야 하고 동의하지 아니한다는 이유로 서비스 제공을 거부해서는 안된다. 따라서 개별시스템 분석 등을 통해 시스템별로

9) 산업기술R&D사업 안내, 신규 R&D 사업 공고/접수, 협약변경 등 R&D 사업관리 지원 시스템(Itech.keit.re.kr)으로 2024년 10월에 R&D 분석 서비스 기능을 추가하여 SROME(Srome.keit.re.kr)으로 변경하여 지원 중
10) 개인정보처리자는 정보주체가 필요한 최소한의 정보 외의 개인정보 수집에 동의하지 아니한다는 이유로 정보주체에게 재화 또는 서비스의 제공을 거부하여서는 아니 된다
11) 개인정보처리자는 다음 각 호의 어느 하나에 해당되는 경우에는 정보주체의 개인정보를 제3자에게 제공(공유를 포함한다. 이하 같다)할 수 있다.
1. 정보주체의 동의를 받은 경우
2. 제15조제1항제2호, 제3호 및 제5호부터 제7호까지에 따라 개인정보를 수집한 목적 범위에서 개인정보를 제공하는 경우

“제3자 제공 동의” 및 현재 가입시 필수로 되어 있는 ITECH(산업기술R&D정보포털) 등의 개선이 필요하다.

[그림 2] 회원 가입시 제3자 제공 동의 및 ITECH 가입 화면

□ 회원 가입시 제3자 동의(필수) 화면

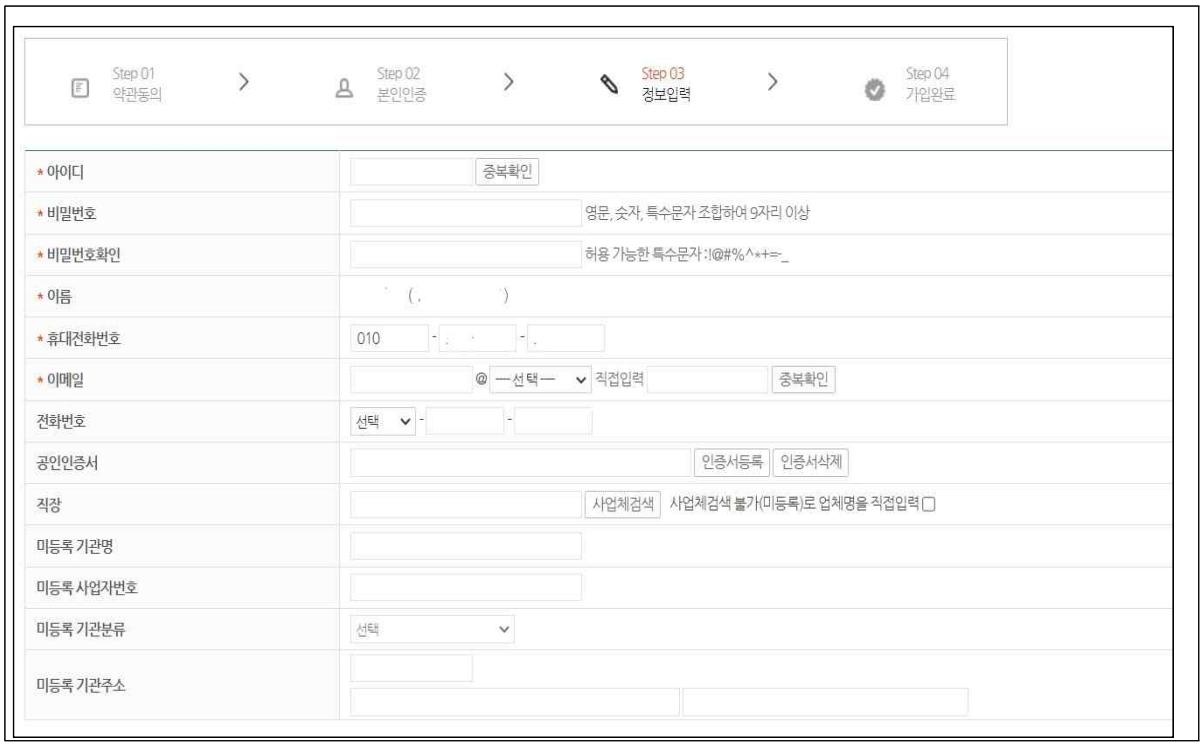
□ 회원 가입시 ITECH 가입 필요

다. 개인정보의 처리 제한

기획평가원의 회원 가입시 [그림 3] 같이 이름, 휴대전화번호, 이메일 등 개인정보 외에 [그림 4]와 같이 가입하고자는 회원이 평가위원, 과제기획위원 자격 등으로 기획·평가위원회에서 수당을 지급 받을 가능성이 있는 경우 관련 수당 지급과 국세청 소득 신고 등을 위해 은행계좌번호

와 주민등록번호를 입력 받고 있다. 그러나 「개인정보 보호법」제24조의2에서는 주민등록번호 수집을 엄격이 제한[12]하고 있으므로 주민등록번호와 은행계좌번호의 경우 회원가입 단계에서 수집하기 보다는 비용을 처리하는 단계에서 수집하는 것이 타당하다.

[그림 3] 회원가입시 개인정보 입력 관련 화면



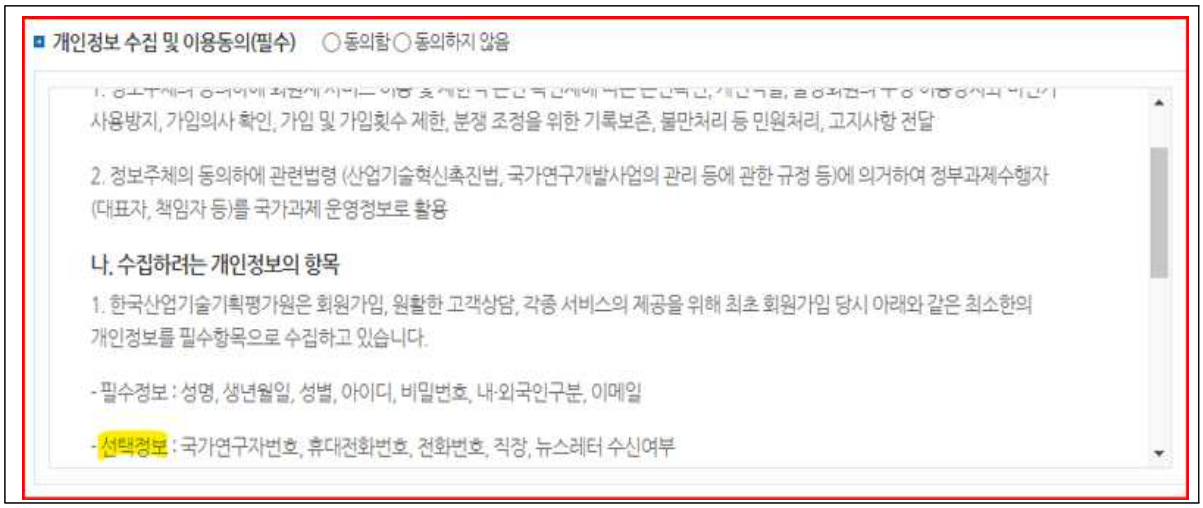
[그림 4] 회원가입시 개인정보 관련 추가 입력화면(평가위원등)

12) 주민등록번호 수집은 "법률·대통령령·국회규칙·대법원규칙·헌법재판소규칙·중앙선거관리위원회규칙 및 감사원규칙에서 구체적으로 주민등록번호의 처리를 요구하거나 허용한 경우" 및 " 정보주체 또는 제3자의 급박한 생명, 신체, 재산의 이익을 위하여 명백히 필요하다고 인정되는 경우"등에 가능

라. 개인정보의 동의 절차

기획평가원의 회원 가입시 [그림 5] 같이 “개인정보수집 및 이용동의 - 수집하려는 개인정보의 항목‘ 중 ‘선택정보’를 포함하여 ‘필수’ 동의 사항으로 정하고 있다. 그러나 「개인정보 보호법」 제22조 ⑤항[13]에 따라서 선택적으로 동의할 수 있는 사항을 동의하지 않는다고 해서 서비스의 제공을 거부하여서는 안 되므로 이에 대한 개선이 필요하다.

[그림 5] “개인정보수집 및 이용동의 관련 ‘선택정보’ 화면



현지조치 사항

□■□■□■■(◎◇◆□■)는 통합고객정보관리시스템(CIMS)를 통한 회원 가입시 안내하는 “이용약관” 제4조(이용계약의 성립)에 대해 「개인정보 보호법」에서 제시하는 용어 및 서비스 범위 등 안내를 명확히 하도록 조치하였다. **【현지시정】**

13) 개인정보처리자는 정보주체가 선택적으로 동의할 수 있는 사항을 동의하지 아니하거나 제1항제3호 및 제7호에 따른 동의를 하지 아니한다는 이유로 정보주체에게 재화 또는 서비스의 제공을 거부하여서는 아니 된다.

관계부서 의견

◎◇◆□■은 통합고객정보관리시스템(CIMS) 회원 가입과 관리 업무 관련 개인정보 처리 및 보호 기준상 개선이 필요한 부분에 대해서 개선을 하겠으나 '개인정보의 정보주체의 동의' 부분 개선 등 일부 사항에 대해서는 통합고객정보관리시스템(CIMS)을 이용하는 시스템에 대한 개별 분석 및 이에 따른 후속처리가 필요하므로 이행에 시간이 소요될 수 있다는 의견을 제시하였다.

조치할 사항

□■□■□■■(◎◇◆□■)는 통합고객정보관리시스템(CIMS) 회원 가입, 관리 관련하여 개인정보 처리 및 보호 기준상 개선이 필요한 부분에 대해서 개선방안을 마련하여 주시기 바랍니다. **【통보】**

일련번호	3	감사자	□★☆, ■◎○, ☆▽■ (교차감사)	공개(○), 비공개(　)	
신분상 조치인원	-	재정상 조치방법	-	재정상 조치금액	-
수감부서 (처리할 부서)	□■□■□■■(□■□△▲△, ◆□■☆★☆▼▲□, ◎◇◆□■)	처분요구일	2024.12.	회신 기한일	2025.02.

통 보 · 개 선 · 현지시정

제　　목　IT개인정보처리시스템 기술적 보호조치 미흡

관 계 부 서　□■□■□■■(□■□△▲△, ◆□■☆★☆▼▲□, ◎◇◆□■)

조 치 부 서　□■□■□■■(□■□△▲△, ◆□■☆★☆▼▲□, ◎◇◆□■)

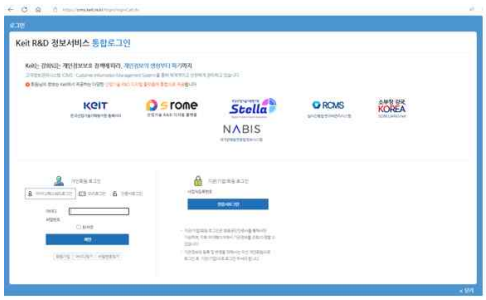
내　　용

1. 업무 개요

한국산업기술기획평가원(이하 '기획평가원'이라 함)은 기관 소개, 국가연구개발사업 평가·관리 등을 위하여 [표 5]과 같이 시스템을 운영하고 있으며 동 시스템의 경우 기관 소개 홈페이지 회원, 국가연구개발사업 과제 수행자 등의 성명, 연락처 등 개인정보를 보관 및 처리하고 있으므로 'IT개인정보처리시스템[14]' 이라고 볼 수 있다.

14) 데이터베이스 시스템 등 개인정보를 처리할 수 있도록 체계적으로 구성한 응용시스템

[표 5] 기획평가원 주요 IT개인정보처리시스템

구 분	내 용	담당부서
KEIT 홈페이지 [www.keit.re.kr]	기관 소개, R&D사업 안내, 정보공개, 제안 및 신고 지원 시스템 	□■□ △▲△
범부처 연구비통합 관리시스템 (RCMS) [www.rcms.go.kr]	국가연구개발사업 등 연구비 집행(지급, 정산 등) 관리 시스템 	◆□■ ☆★☆ ▼▲□
디지털평가시스템 (Stella) [stella.keit.re.kr]	국가연구개발사업 등 과제평가지원시스템 	
통합고객정보 관리시스템 (CIMS) [cims.keit.re.kr]	홈페이지 회원, 국가연구개발사업 과제 수행자 등 개인정보 관리 시스템  	◎◇ ◆□■

2. 관련 법령(규정) 및 판단기준

「개인정보 보호법」 제29조[15] 및 개인정보보호위원회 고시 「개인정보의 안전성 확보조치 기준」 제6조～제14조[16]에 따라 개인정보보호를 위하여 IT개인정보처리시스템는 기술적·관리적 및 물리적 조치를 하여 안전성을 확보하여야 한다.

3. 감사결과 확인된 사항

기획평가원에서 운영 중인 주요 IT개인정보처리시스템의 기술적 취약점 점검을 위하여 사전조사 기간인 2024. 8. 12. 부터 같은해 8. 23. 동안 외부 개인정보보호 전문기관과 공동으로 개인정보의 안전성 확보가 필요한 "접근 권한의 관리" 등 「개인정보의 안전성 확보조치 기준」 제6조～제14조에서 제시하고 있는 9개 항목에 대해 [표 6]과 같이 세부 기준을 마련하고 담당자 인터뷰 및 실지조사 등의 방법으로 점검을 실시하였다.

15) 개인정보처리자는 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 하여야 한다

16) 접근권한의 관리, 접근통제, 개인정보의 암호화, 접속기록의 보관 및 점검, 악성프로그램 등 방지, 물리적 안전조치, 재해·재난 대비 안전조치, 출력·복사 시 안전조치, 개인정보의 파기

[표 6] 개인정보의 안전성 확보조치 점검 항목 및 기준

번호	구분	평가항목
1	접근 권한의 관리	개인정보처리시스템에 대한 접근 권한을 개인정보취급자에게만 업무 수행에 필요한 최소한의 범위로 차등 부여 여부
2		개인정보취급자 또는 개인정보취급자의 업무가 변경되었을 경우 지체 없이 개인정보처리시스템의 접근 권한을 변경 또는 말소 여부
3		개인정보처리시스템에 대한 접근 권한의 부여·변경·말소 내역의 기록 관리 및 최소 3년간 보관 여부
4		개인정보처리시스템에 접근할 수 있는 계정을 발급하는 경우 정당한 사유가 없는 한 개인정보취급자 별로 계정을 발급하고 다른 개인정보취급자와 미공유 여부
5		개인정보취급자 및 정보주체의 인증수단을 안전하게 적용하고 관리하고 있습니까?(인증수단으로 비밀번호를 사용하는 경우 비밀번호 작성규칙 대로 설정 여부
6		인증수단으로 비밀번호를 사용하는 경우 개인정보취급자 및 정보주체의 비밀번호를 주기적으로 변경 설정 여부
7		개인정보처리자는 정당한 권한을 가진 개인정보취급자 또는 정보주체만이 개인정보처리시스템에 접근할 수 있도록 일정 횟수 이상 인증에 실패한 경우 개인정보처리시스템에 대한 접근을 제한하는 등 필요한 조치 여부
8	접근통제	개인정보처리시스템에 대한 불법적인 접근 및 침해사고를 방지를 위해 인가받지 않은 IP 주소 등을 제한 및 개인정보 유출 시도 탐지 및 대응을 위한 접근통제시스템을 설치 및 운영 여부
9		개인정보취급자가 정보통신망을 통해 외부에서 개인정보처리시스템에 접속하려는 경우 인증서, 보안토큰, 일회용 비밀번호 등 안전한 인증수단을 적용 여부
10		개인정보가 인터넷 홈페이지, P2P, 공유설정 등을 통하여 권한이 없는 자에게 공개되거나 유출되지 않도록 개인정보처리시스템, 개인정보취급자의 컴퓨터 및 모바일 기기 등에 조치 여부
11		개인정보처리시스템에 대하여 일정시간 이상 업무처리가 없을 경우 자동으로 시스템 접근을 차단하는 기술적 조치 여부
12		업무용 모바일 기기의 분실·도난 등으로 개인정보가 유출되지 않도록 해당 모바일 기기에 비밀번호 설정 등의 보호조치 여부
13		개인정보처리시스템에서 개인정보를 다운로드 또는 파기할 수 있거나 개인정보처리시스템에 대한 접근 권한을 설정할 수 있는 개인정보취급자의 컴퓨터 등에 인터넷망 차단 조치를 실시 여부
14	개인정보의 암호화	비밀번호, 생체인식정보 등 인증정보 및 주민등록번호를 저장하는 경우 안전한 암호 알고리즘으로 암호화하여 저장 여부
15		비밀번호는 복호화되지 않도록 안전한 방식으로 일방향 암호화하여 저장 여부?(SHA-256 이상 또는 이에 상응하는 암호화 알고리즘)
16		이용자의 개인정보(고유식별정보, 신용카드번호, 계좌번호, 생체인식정보)를 저장하는 경우 안전한 암호 알고리즘으로 암호화하여 저장 여부

17		고유식별정보를 인터넷망 구간과 내부망의 중간 지점(DMZ)에 저장하는 경우 안전한 암호화 알고리즘으로 암호화하여 저장 여부
18		이용자의 개인정보 또는 이용자가 아닌 정보주체의 고유식별정보를 개인정보취급자의 컴퓨터, 모바일 기기 등 보조저장매체에 저장하는 경우 안전한 암호화 알고리즘으로 암호화하여 저장 여부
19		비밀번호, 생체인식정보 등 인증정보를 정보통신망을 통하여 송·수신하는 경우 안전한 암호 알고리즘으로 암호화 여부
20		개인정보를 정보통신망을 통하여 인터넷망 구간으로 송·수신하는 경우 안전한 암호 알고리즘으로 암호화 여부
21		암호화된 개인정보를 안전하게 보관하기 위하여 안전한 암호키 생성, 이용, 보관, 배포 및 파기 등에 관한 절차를 수립·시행 여부
22	접속기록의 보관 및 점검	개인정보취급자가 개인정보처리시스템에 접속한 기록을 최소 1년 이상 보관·관리 여부
23		접속기록에 ID, 날짜 및 시간, IP 주소, 수행업무(입력, 조회, 수정, 삭제, 인쇄 등), 처리한 정보주체 정보 등 필요한 사항이 모두 기록 여부
24		개인정보의 오·남용, 분실·도난·유출·위조·변조 또는 훼손 등에 대응하기 위하여 개인정보처리시스템의 접속기록 등을 월 1회 이상 점검 여부
25		개인정보처리자는 개인정보취급자의 접속기록이 위·변조 및 도난, 분실되지 않도록 해당 접속기록을 안전하게 보관 여부
26	악성프로그램 등 방지	개인정보 처리 단말기에 악성프로그램을 점검, 치료할 수 있는 백신프로그램 등을 설치하고 업데이트를 최신으로 유지 여부
27	물리적 안전 조치	전산실, 자료보관실 등 개인정보를 보관하고 있는 물리적 보관 장소를 별도로 두고 있는 경우에는 이에 대한 출입통제 절차를 수립・운영 여부
28	재해·재난 대비 안전조치	화재, 홍수, 단전 등의 재해・재난 발생 시 개인정보처리시스템 보호를 위한 조치 여부
29	출력·복사시 안전조치	개인정보처리시스템에서 개인정보의 출력 시(인쇄, 화면표시, 파일생성 등) 용도를 특정하여야 하며, 용도에 따라 출력 항목을 최소화하고 있습니까?
30		개인정보가 포함된 종이 인쇄물, 개인정보가 복사된 외부 저장매체 등 개인정보의 출력・복사물을 안전하게 관리하기 위해 필요한 안전조치를 하고 있습니까?
31	개인정보의 파기	개인정보가 포함된 문서 및 파일 등을 파기 시 복구 및 재생 불가능한 방법으로 파기 여부
32		완전파기 및 부분파기 등 기술적 특성으로 파기하는 것이 현저히 곤란하는 경우 시간・비용・기술 등을 합리적으로 고려할 때 다른 정보를 사용하여도 더 이상 개인을 알아볼 수 없는 정보로 처리하여 복원이 불가능하도록 조치 여부

[표 6]의 점검항목으로 4개의 IT개인정보처리시스템에 대해 점검한 결과, 17건의 개선이 필요한 것으로 조사 되었다.

현지조치 사항

□■□■□■■(◆□■☆★☆▼▲□)는 범부처 연구비통합관리시스템(RCMS) 시스템관리자 페이지에서의 접근권한 말소 또는 삭제시 로그가 기록 되도록 기능을 개선조치 하였다. 【현지시정】

관계부서 의견

□■□△▲△, ◆□■☆★☆▼▲□및 ◎◇◆□■은 IT개인정보처리시스템에 대한 개인정보의 안전성 점검 결과 확인된 취약점에 대해 개선을 하겠으나 “개인정보 접근 기록 솔루션”, “접속기록의 보관 및 점검” 등 일부 개선 항목의 경우 예산 확보 후 추진해야 하므로 이행에 시간이 소요될 수 있다는 의견을 제시하였다.

조치할 사항

① □■□■□■■(□■□△▲△)은 기관 홈페이지에 대한 개인정보의 안전성 점검 결과 확인된 “접근 권한의 관리” 등 취약점에 대해 개선방안을 마련하여 주시기 바랍니다.【통보】

② □■□■□■■(◆□■☆★☆▼▲□)은 디지털평가시스템(Stella) 및 범부처 연구비통합관리시스템(RCMS)에 대한 개인정보의 안전성 점검 결과 확인된 “접근 권한의 관리”, “접속기록의 보관 및 점검” 등 취약점에 대해 개선방안을 마련하여 주시기 바랍니다. **【통보】**

③ □■□■□■■(◎◇◆□■)은 통합고객정보관리시스템(CIMS)에 대한 개인정보의 안전성 점검 결과 확인된 “접속기록의 보관 및 점검” 등 취약점에 대해 개선하여 주시기 바랍니다. **【개선】**

일련번호	4	감사자	□★☆, ▽▼▲, ◆▲● (교차감사)	공개(○), 비공개(　)	
신분상 조치인원	-	재정상 조치방법	-	재정상 조치금액	-
수감부서 (처리할 부서)	□■□■□■■(□■□△▲△, ◆□■☆★☆▼▲□, ◎◇◆□■)	처분요구일	2024.12.	회신 기한일	2025.02.

통 보 · 개 선

제　　목　IT개인정보처리시스템에 대한 개인정보 안정성 확보 조치 미흡

관 계 부 서　□■□■□■■(□■□△▲△, ◆□■☆★☆▼▲□, ◎◇◆□■)

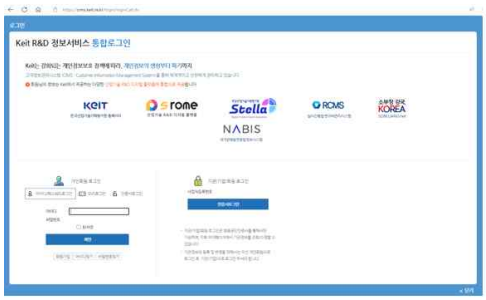
조 치 부 서　□■□■□■■(□■□△▲△, ◆□■☆★☆▼▲□, ◎◇◆□■)

내　　용

1. 업무 개요

한국산업기술기획평가원(이하 '기획평가원'이라 함)은 기관 소개, 국가연구개발사업 평가·관리 등을 위하여 [표 8]과 같이 시스템을 운영하고 있으며 동 시스템의 경우 기관 소개 홈페이지 회원, 국가연구개발사업 과제 수행자 등의 성명, 연락처 등 개인정보를 보관 및 처리하고 있으므로 'IT개인정보처리시스템[17]' 이라고 볼 수 있다.

[표 8] 기획평가원 운영 주요 IT개인정보처리시스템

구 분	내 용	담당부서
KEIT 홈페이지 [www.keit.re.kr]	• 기관 소개, R&D사업 안내, 정보공개, 제안 및 신고 지원 시스템 	□■□ △▲△
통합연구비관리시스템 (RCMS) [www.rcms.go.kr]	• 국가연구개발사업 등 연구비 집행(지급, 정산 등) 관리 시스템 	◆□■ ☆★☆ ▼▲□
디지털평가시스템 (Stella) [stella.keit.re.kr]	• 국가연구개발사업 등 과제평가지원시스템 	
통합고객정보 관리시스템 (CIMS) [cims.keit.re.kr]	• 홈페이지 회원, 국가연구개발사업 과제 수행자 등 개인정보 관리 시스템  	◎◇ ◆□■

17) 데이터베이스 시스템 등 개인정보를 처리할 수 있도록 체계적으로 구성한 응용시스템

2. 관련 법령(규정) 및 판단기준

「개인정보 보호법」 제29조[18] 및 기획평가원 「개인정보 보호지침」 제19조[19]에 따라 개인정보보호를 위하여 IT개인정보처리시스템의 기술적 조치를 하여 안전성을 확보하여야 한다.

3. 감사결과 확인된 사항

기획평가원에서 운영 중인 주요 IT개인정보처리시스템의 기술적 취약점 점검을 위하여 사전조사 기간인 2024. 8. 12. 부터 같은해 8. 23. 동안 외부 개인정보보호 전문기관과 공동으로 “주요정보통신기반기술 기술적 취약점 분석·평가 방법 상세가이드(과학기술정보통신부·한국인터넷진흥원, 2021.3.)”에서 제시한 Web 취약점 분석·평가를 모의해킹 형식으로 점검하였다.

4개의 IT개인정보처리시스템에 대해 모의 해킹을 수행한 결과, 19개의 취약점이 발견되어 개선이 필요한 것으로 확인하였다.

---

18) 개인정보처리자는 개인정보가 분실・도난・유출・위조・변조 또는 훼손되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적・관리적 및 물리적 조치를 하여야 한다

19) 수탁자는 위탁받은 개인정보를 보호하기 위하여 개인정보보호위원회의「개인정보의 안전성 확보조치 기준」에 따른 관리적·기술적·물리적 조치를 하여야 한다.

관계부서 의견

□■□△▲△, ◆□■☆★☆▼▲□및 ◎◇◆□■은 IT개인정보처리시스템에 대한 Web 취약점 분석·평가 결과에 대해 수용하면서 취약점에 대해 개선을 하겠으나 “파일 업로드” 등 개선 사항은 예산 확보 후 추진해야 하므로 이행에 시간이 소요될 수 있다는 의견을 제시하였다.

조치할 사항

① □■□■□■■(□■□△▲△)은 기관 홈페이지에 대한 Web 취약점 분석·평가 결과 확인된 “파일업로드”, “프로세스 검증 누락” 등 취약점에 대해 개선방안을 마련하여 주시기 바랍니다. **【통보】**

② □■□■□■■(◆□■☆★☆▼▲□)은 디지털평가시스템(Stella) 및 통합연구비관리시스템(RCMS)에 대한 Web 취약점 분석·평가 결과 확인된 “파일업로드”, “프로세스 검증 누락” 등 취약점에 대해 개선방안을 마련하여 주시기 바랍니다. **【통보】**

③ □■□■□■■(◎◇◆□■)은 통합고객정보관리시스템(CIMS)에 대한 Web 취약점 분석·평가 결과 확인된 “불충분한 세션 만료” 등 취약점에 대해 개선하여 주시기 바랍니다. **【개선】**

일련번호	5	감사자	●☆☆, ★◎ (준감사인)	공개(○), 비공개( )	
신분상 조치인원	-	재정상 조치방법	-	재정상 조치금액	-
수감부서 (처리할 부서)	▽■◆□■◆□(○■▼▽■)	처분요구일	2024.12.	회신 기한일	-

주 의

제 목 개인정보 처리 업무 부적정

관 계 부 서 공급망산업본부(○■▼▽■)

조 치 부 서 공급망산업본부(○■▼▽■)

1. 업무 개요

한국산업기술기획평가원(이하 “기획평가원”이라 한다)은 산업기술혁신사업으로 지원되는 연구개발과제의 기획 및 평가·관리 등의 업무를 담당하는 전문기관으로 「산업기술혁신사업 기술개발 평가관리지침」에 의거하여 연구개발과제의 사전기획 수행기간 중 의견 수렴을 위해 인터넷 공시, 공청회 등을 실시할 수 있으며, 연구개발과제 또는 품목 기획 결과로 확정된 지원대상 연구개발과제의 제안요구서(RFP) 또는 품목을 공고하는 업무를 수행하고 있다.

한편, 기획평가원은 ‘□□ □□□□ □□ □□□□ □□□사업’을 2024년 4월 공고하여 지원하고 있으며, 해당 사업의 기획·평가·관리 업무는 ○■▼▽■에서 담당하고 있다.

2. 관련 규정 및 판단기준

기획평가원 「개인정보 보호지침」 제3조제1호 및 제7조제1항에 의하면 개인정보란 살아 있는 개인에 관한 정보로서 성명, 주민등록번호 및 영상 등을 통하여 개인을 알아볼 수 있는 정보를 말하며, 개인정보처리자는 정보주체의 동의를 받은 경우에는 정보주체의 개인정보를 제3자에게 제공할 수 있다.

또한 같은 지침 제4조제2항 및 제28조제3호에 의하면 개인정보처리자는 개인정보의 처리목적에 필요한 범위에서 적합하게 개인정보를 처리하여야 하며, 개인정보처리자의 고의 또는 과실로 인해 개인정보가 포함된 파일 또는 종이문서, 기타 저장매체가 권한이 없는 자에게 잘못 전달된 경우를 개인정보의 유출이라고 한다.

따라서 기획평가원 직원은 기획·평가·관리 업무를 처리하는 과정에서 연구자의 개인정보를 적법하고 정당하게 수집·활용하여야 한다.

3. 감사결과 확인된 문제점

이번 특정감사 기간 동안 개인정보 처리업무의 적정성을 검토한 결과, 신규지원 대상과제를 공고하는 과정에서 기획평가원 담당자의 개인정보 처리 업무의 부적정 사항이 확인되었다.

○■▼▽■에서 연구개발과제 기획 및 공고 업무를 담당하는 ★★○★□은 2024년 4월 15일 범부처통합연구지원시스템(http://www.iris.go.kr)을 통해 '□□ □□□□ □□ □□□□ □□□사업(이하 "□□□ 사업"이라 한다)'의 신규지원 대상과제 공고문을 등록하였다.

그리고 ★★○ ★□은 2024년 3월 13일부터 동년 동월 19일까지 진행된 □□□ 사업의 신규기획과제에 대한 '인터넷 공시 접수 의견별 반영결과'를 공고문의 붙임자료로 첨부하였다.

그 과정에서 ★★○ ★□은 인터넷 공시 의견을 제출한 13명의 개인정보(이름, 소속기관)를 정보주체인 제안자의 동의도 받지 않은 채 인터넷에 게시하였을 뿐만 아니라, 해당 개인정보를 가명 또는 익명처리도 하지 않은 것으로 확인되었다.

사업 공고 이후 7일이 지난 4월 22일, ★★○ ★□은 공고문에 개인정보가 포함되었다는 사실을 인지하고, 해당 붙임자료(인터넷 공시 의견별 반영결과)를 삭제한 후 공고문을 재등록하였다.

한편 기획평가원의 ◎◇◆□■은 1) 4월 23일 개인정보가 유출된 정보주체 13명에게 전화, 문자, 이메일을 통해 관련 내용을 개별적으로 통지하였고, 2) 산업부 사이버안전센터로 개인정보 유출 내용을 신고하였으며, 3) 원내 그룹웨어 게시판을 통해 전직원에게 사례를 전파하고, 4) 5월 27일 ★★○ ★□에게 정보보안위험지수 벌점 12점을 부과하고 특별교육을 실시하는 등 후속조치를 신속하게 추진하였다.

다만 이번 개인정보 유출 사고는 1) ★★○ ★□이 공고문을 편집하는 과정에서 단순 실수로 인하여 발생한 사건으로 고의성이 없었던 점, 2) 사업 공고 후 7일차에 개인정보가 포함된 공고문을 수정·재등록하여 공개 기간이 길지 않았던 점, 3) 제안자 13명의 이름과 소속기관 정보는 '개인정보 등급 분류표[20]' 중 상대적으로 민감성이 낮은 3등급에 해당

20) 개인정보 등급 분류표(문화체육관광부 개인정보 보호지침 [별표 2])

하는 점, 3) 개인정보 유출 후 정보주체인 제안자에게 안내된 피해 신고가 접수되지 않았던 점을 고려할 때 이번 개인정보 유출로 인한 피해의 정도는 크지 않은 것으로 사료된다.

그럼에도 불구하고 국가연구개발사업에 참여하는 연구수행자의 개인정보를 취급하는 기획평가원 직원이 업무를 처리하는 과정에서 정보주체의 개인정보를 제3자에게 제공함으로써 개인정보를 유출한 관련자에 대하여 재발방지를 위하여 주의 조치가 필요하다.

관계부서 의견

사업 공고 업무와 관련된 기획평가원 관련자는 개인정보 처리를 소홀히 한 점을 인정하며, 유사사례가 발생하지 않도록 관련 업무를 철저히 하겠다는 의견을 제시하였다.

등급	조합 수준	개인정보 항목
1	개인을 식별할 수 있으며, 악용할 경우 위험이 매우 큰 정보	주민등록번호,여권번호, 외국인등록번호, 운전면허번호, 신용카드번호, 카드비밀번호, 계좌번호, 아이디, 비밀번호
2	개인을 식별할 수 있으며, 악용할 경우 위험이 높은 정보	이름, 주소, 전화번호, 핸드폰번호, 이메일주소, 인종, 종교, 병역, 사회단체활동, 보건 등
3	개인을 식별할 수 있으며, 악용할 경우 위험이 낮은 정보	이름, 주소, 전화번호, 핸드폰번호, 이메일 주소 등
4	개인을 식별할 수 없으나, 개인을 식별할 수 있는 정보와 같이 노출 시 위험이 높은 정보	인종, 종교, 병역, 사회단체활동, 보건 등
5	정보가치가 낮은 정보	일반정보(개인정보없음)

조치할 사항

사업 공고 업무를 처리하는 과정에서 이름과 소속기관 정보가 포함된 붙임자료를 첨부하여 개인정보를 유출한 관련자에게 재발방지를 위해 주의를 촉구합니다. 【주의】

[관련자] ○■▼▽■ ▲◎(★□) ★ ★ ○

일련번호	1	감사자	◎◎●	공개(○), 비공개(　)	
신분상 조치인원	-	재정상 조치방법	-	재정상 조치금액	-
수감부서 (처리할 부서)	□■□■□■■ (□■□△▲△)	처분요구일	2024.12.	회신 기한일	-

모 범 사 례

제　　목　**퇴직자 개인정보관리체계 개선을 통한 통한 보안성 및 업무 효율성 강화에 기여**

관 계 부 서　**□■□■□■■(□■□△▲△)**

조 치 부 서　**□■□■□■■(□■□△▲△)**

내　　용

한국산업기술기획평가원(이하 '기획평가원'이라 한다)은 임직원이 퇴사할 경우 중요문서, 개인정보 등의 유출을 방지하기 위해 기획평가원 정보시스템에 대한 접근을 차단하고, 제한지역인 평가관리원 전지역 내의 비밀 또는 정부 재산의 보호를 위해 퇴직자 등의 출입을 제한하는 통제 조치를 취하고 있다.

이와 관련하여, 퇴직한 임직원에 대하여 즉시 정보시스템 접근 권한을 통제함으로써, 권한 없는 자가 평가관리시스템(ITECH, STELLA)을 포함한 평가관리원의 정보시스템에 접근하여 평가위원, 연구수행자 등의 개인정보, 연구과제 수행기록 등의 유출을 초래할 위험을 제거할 필요가 있다.

이를 위하여 임직원이 퇴직할 경우 즉각적인 권한회수로 개인정보 관리가 차질 없이 이루어질 수 있도록 □■□△▲△ ◎▼■ ▼◎은 다음과 같

이 전산시스템을 개선하였다.

첫째, 직원 개인정보관리를 통합고객정보관리시스템(CIMS)으로 통합하여 경영시스템에서 별도 관리하던 개인정보를 통합고객정보관리시스템(CIMS)로 일원화하고 개인정보 보관·이용의 안전성 확보 및 관리 효율성을 제고하였다.

둘째, 인사시스템 연동을 통한 퇴직자 권한 자동 회수 기능을 구현하여 인사 발령 정보와 연계하여 퇴직일에 맞춰 GW, PMS 등 5개 시스템의 접속 권한 회수 및 통합고객정보관리시스템(CIMS)의 소속기관 정보변경 등의 처리를 자동화하였다.

셋째, 홈페이지 관리자 계정을 고객정보관리시스템과 연동하여 임의로 관리자계정 생성이 가능하게 함으로써 실사용자 식별이 불가한 권한관리체계를 CIMS와 연계한 사용자 식별, 권한 자동 회수가 가능하도록 시스템을 개선하였다.

이로써, 불필요한 개인정보 중복 저장·관리 제거 및 누락없는 퇴직자 권한 회수를 통해 기술적, 인적 보안사고를 미연에 방지하고, 퇴직 발생 시마다 담당자가 직접 수행하던 퇴직자 권한 회수 업무를 데이터 기반으로 자동화하여 업무 효율과 생산성 향상에 기여하였다.

조치할 사항

□■□■□■■(□■□△▲△장)은 적극적인 업무추진으로 개인정보 관리체계를 개선하여 보안성 및 업무 효율성 강화에 기여한 관련자에게 타의 모범이 될 수 있도록 격려해주시기 바랍니다. **【모범사례】**

[관련자] □■□△▲△ 5급(▼◎) ◎ ▼ ■

컨설팅감사 결과 모범사례

소 속	직 급	성 명
□■□△▲△	▼◎	◎▼■

제목: 개인정보 및 권한 관리체계 개선을 통한 보안성 및 업무효율성 강화

추 천 내 용

□ (추진배경) 퇴직 발생 時 권한회수 및 개인정보 관리를 위한 업무 개선 필요

○ 現 업무시스템은 권한관리를 개별 운영*하여 퇴직 발생 시 각 시스템 담당자가 권한을 회수하는 방식으로, 누락 가능성이 존재하며 보안상의 문제도 우려

* 업무시스템 : 그룹웨어, 과제관리시스템, 통합고객정보관리시스템(CIMS), 홈페이지 등

○ 舊 행정관리시스템(MIS)은 입사 시 직원 개인정보를 수집하여 준영구 보관하나, 퇴직자 개인정보 보호를 위한 안전성 확보조치는 보완 필요

□ (주요내용) 개인정보관리체계 일원화 및 퇴직자 권한 자동 회수 기능 구축

① (개인정보 관리 일원화) 직원 개인정보관리를 CIMS로 통합

- 경영시스템에서 별도 관리하던 개인정보를 CIMS로 일원화*하여 개인정보 보관・이용의 안전성 확보 및 관리 효율성 제고

* 주민등록번호 등 개인정보를 CIMS와 연계하여 경영시스템 內 개인식별정보 Zero화

② (퇴직자권한 회수) 인사시스템 연동을 통한 퇴직자 권한 자동 회수 기능 구현

- 인사 발령 정보와 연계하여 퇴직일에 맞춰 GW, PMS 등 5개 시스템의 접속 권한 회수 및 CIMS의 소속기관 정보 등 데이터 처리 자동화

* 인사 변동사항을 모니터링하여 퇴직일 다음날 권한 회수, 소속기관 정보 삭제 등 수행

③ (관리자 계정관리 개선) 홈페이지 관리자 계정을 CIMS와 연동

- 임의로 관리자계정 생성이 가능해 실사용자 식별이 불가한 권한관리체계를 CIMS와 연계하여 사용자 식별, 권한 자동 회수가 가능하도록 시스템 개선

□ (기대효과) 우리 원 개인정보의 보안성 강화 및 업무효율 향상

○ 불필요한 개인식별정보 중복 저장·관리를 제거하고, 누락없는 퇴직자 권한 회수를 통해 기술적, 인적 보안사고를 미연에 방지

○ 퇴직 발생 시마다 담당자가 직접 수행하던 퇴직자 권한 회수 업무를 데이터 기반으로 자동화하여 업무 효율과 생산성 향상

일련번호	2	감사자	□★☆	공개(○), 비공개(　)	
신분상 조치인원	-	재정상 조치방법	-	재정상 조치금액	-
수감부서 (처리할 부서)	□■□■□■■ (◎◇◆□■)	처분요구일	2024.12.	회신 기한일	-

모 범 사 례

제　　목 **“개인정보 내부관리 계획” 수립, 이행 및 전파를 통한 개인정보보호 강화에 기여**

관 계 부 서 **□■□■□■■(◎◇◆□■)**

조 치 부 서 **□■□■□■■(◎◇◆□■)**

내　　용

한국산업기술기획평가원(이하 ‘기획평가원’이라 한다)은 「개인정보 보호법」 제29조(안전조치의무)에 의거 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 “개인정보 내부관리 계획” 내 기술적・관리적 및 물리적 조치와 교육 계획을 수립하고 이행하여 개인정보를 안전하게 관리하여야 한다.

개인정보보호 담당자인 ◎◇◆□■ ◇▼★ ◇☆은 다음과 같이 적극적인 업무자세로 개인정보 내부 관리계획 수립 및 이행 등을 통하여 기획평가관리원 개인정보보호 강화에 기여하였다.

첫째, [표 11]과 같이 기존 “개인정보 내부관리 계획” 의 경우 「개인정보보호법」 및 동법 시행령 등에서 제시하고 있는 개인정보보호 사항에 대하여 나열 형식으로 수립되었으나 ◇▼★ ◇☆이 개인정보보호 업무 담당

후에는 전 직원이 쉽게 이해하고 이행 및 확인할 수 있도록 관련 매뉴얼, 절차서, 주요점검 일정 및 교육 계획(안) 등을 추가하여 “개인정보 내부관리 계획”을 운용하고 있다.

[표 11] “개인정보 내부관리 계획” 개요

변경전	변경후
2021년 6월 내부관리계획 (총 21 page)	2024년 9월 내부관리계획 (총 284 page)
목 차 1. 총칙 ---- 1 2. 내부관리계획 수립 및 시행 ---- 1 3. 개인정보 보호책임자(CPO) 등 지정 ---- 3 4. 개인정보 보호책임자(CPO) 등 역할 및 책임 ---- 4 5. 개인정보의 기술적 · 관리적 · 물리적 안전조치 ---- 6 6. 수탁자에 대한 관리 및 감독 ---- 13 7. 개인정보보호 교육 및 홍보 ---- 15 8. 가명정보의 안전한 관리 ---- 16 [부록1] 개인정보처리시스템 접근권한 및 접속기록 관리 정책서 [부록2] 개인정보 목적 외 이용·제3자 제공 절차서 [부록3] 개인정보 침해·유출사고 대응 절차서 [부록4] 개인정보처리시스템 재해재난대비 위기대응 매뉴얼 [부록5] 정보주체 권리보장 절차서 [부록6] 가명정보 처리 절차서	목 차 제 · 개정 이력 ---- 1 법적근거 ---- 7 개인정보 내부관리 계획 개요 ---- 9 제1장 총칙 ---- 10 제1조(목적) 제2조(용어 정의) 제3조(안전조치의 적용 원칙) 제3조2 (적용 범위) 제2장 내부 관리계획의 수립 및 시행 ---- 12 제4조(내부 관리계획의 수립 · 시행 및 점검) 제5조(내부 관리계획의 공표) 제3장 개인정보 보호책임자(CPO)의 역할 및 책임 ---- 14 제6조(개인정보 보호책임자의 지정) 제7조(개인정보 보호책임자의 역할 및 책임) 제8조(분야별 개인정보 보호책임자 등의 지정) 제9조(개인정보 취급자의 역할 및 책임) 제4장 개인정보 보호교육 ---- 16 제10조(개인정보 보호책임자의 교육) 제11조(임직원 및 개인정보 취급자의 교육) 제5장 기술적 안전조치 ---- 18 제12조(접근 권한의 관리) 제13조(접근 통제) 제14조(개인정보의 암호화)
	제15조(접속기록의 보관 및 점검) 제16조(악성프로그램 등 방지) 제17조(관리용 단말기의 안전조치) 제18조(출력 · 복사시 안전조치)[신규] 제19조(개인정보의 파기) 제6장 관리적 안전조치 ---- 24 제20조(개인정보 보호조직 구성 및 운영) 제21조(개인정보 유출 사고 대응) 제22조(위험도 분석 및 대응) 제23조(수탁자에 대한 관리 및 감독) 제24조(개인정보보호 홍보) 제7장 물리적 안전조치 ---- 26 제25조(물리적 안전조치) 제26조(재해 및 재난 대비 안전조치) 제8장 가명정보의 처리 및 보호조치 ---- 27 제27조(가명정보 및 추가정보 관리책임자 지정) 제28조(가명정보 및 추가정보 별도 분리 보관 및 접근권한 관리) 제29조(가명정보 또는 추가 정보의 안전성확보 조치에 관한 사항) 제30조(가명정보처리자의 교육에 관한 사항) 제31조(가명정보 처리 기록 작성 및 보관에 관한 사항) 제32조(가명정보 등 개인정보 처리방침 공개에 관한 사항) 제33조(가명정보의 재식별 금지에 관한 사항) 제9장 인공지능(AI) 개인정보보호 자율점검 ---- 29 제34조(기본원칙 준수) 제35조(인공지능(AI) 서비스 개인정보보호 자율점검표 활용) 제10장 영상정보처리 기기 안전성 확보조치 ---- 30 제36조(영상정보처리기기 설치, 운영 및 개인영상정보 보호) 제37조(고정형 영상정보처리기기 운영·관리 방침)
	제38조(고정형 영상정보처리기기 관리책임자의 지정) 제39조(고정형 영상정보처리기기 안내판의 설치) 제40조(고정형 영상정보처리기기 영상정보처리기기 안전성 확보 조치) 제41조(개인영상정보 이용·제3자 제공 등 제한 등) 제42조(개인영상정보의 보관 및 파기) 제43조(개인영상정보의 이용·제3자 제공·파기의 기록 및 관리) 제44조(개인영상정보처리기기 설치, 운영에 대한 점검) 제45조(정보주체의 열람 등 요구) 제46조(개인영상정보 관리대장) 제47조(정보주체 이외의 자의 개인영상정보 보호) 제48조(이동형 개인영상정보처리기기 설치, 운영에 대한 점검) 제11장 공공시스템 운영기관 등의 개인정보 안전성 확보조치 ---- 35 제49조(공공시스템운영기관의 안전조치 기준 적용) 제50조(공공시스템운영기관의 내부 관리계획의 수립 · 시행) 제51조(공공시스템운영기관의 접근 권한의 관리) 제52조(공공시스템운영기관의 접속기록의 보관 및 점검) 제12장 개인정보 목적 외 이용 및 제3자 제공 안전조치 ---- 37 제53조(개인정보의 목적 외 이용·제공 제한) 제54조(개인정보를 제공받은 자의 이용·제공 제한) 제13장 정보주체 권리보장 ---- 39 제55조(정보주체 이외로부터 수집한 개인정보의 수집·출처 등의 통지) 제56조(개인정보 이용·제공 내역의 통지) 제14장 개인정보의 유출, 도난 방지 등을 위한 취약점 점검 ---- 40 제57조(취약점 점검 및 조치) [붙임 1] 접근권한 관리 기준 강화 ---- 41 [붙임 2] 2024 월별 개인정보 보호 중점 활동 추진 계획 ---- 42 [붙임 3] 연간 정보보안 · 개인정보보호 주요점검 일정 ---- 44
	(부록 1) 2023년 개인정보보호교육 계획안 ---- 45 【 서식 1-1 】 개인정보보호교육 결과 보고서 【 서식 1-2 】 개인정보보호교육 결과 회의록 (부록 2) 개인정보처리시스템 접근권한 및 접속기록 관리 매뉴얼 ---- 50 【 서식 2-1 】 DB 개인정보 접근권한 신청(변경)서 【 서식 2-2 】 개인정보 접근기록·접속기록·보유현황·암호화 현황 점검대장 【 서식 2-3 】 개인정보 접속기록 상세 점검내역 【 서식 2-4 】 개인정보 접근권한 관리 자체점검표 (부록 3) 개인정보 침해·유출사고 대응 매뉴얼 ---- 64 【 부록 3. 서식 1 】개인정보 유출신고서(양식 및 사례) 【 부록 3. 서식 2 】 개인정보 유출신고 조치확인서(양식 및 사례) 【 부록 3. 서식 3 】 개인정보 침해·유출사고 처리보고서(양식) 【 부록 3. 서식 4 】 개인정보 침해사실 신고서 【 부록 3. 참고 1 】 유출 통지방법 【 부록 3. 참고 2 】 표준 개인정보 유출 통지문 (예시) 【 부록 3. 참고 2-1 】 개인정보 유출 통지문"해킹에 의한 유출" 【 부록 3. 참고 2-2 】 개인정보 유출 통지문"내부직원에 의한 유출" 【 부록 3. 참고 2-3 】 개인정보 유출 통지문"용역사(수탁사)에 의한 유출" 【 부록 3. 참고 2-4 】 개인정보 유출 통지문"이벤트사 용역사 부주의에 의한 노출" 【 부록 3. 참고 3 】 개인정보 유출 신고서 (예시) 【 부록 3. 참고 4 】 상황 중료 보고(예시) 【 부록 3. 참고 5 】 개인정보보호 포털 유출신고 절차 및 방법 【 부록 3. 참고 6 】 침해사고 신고 및 경찰 수사 연락처 【 부록 3. 참고 7 】 침해사고 대응 체크리스트 【 부록 3. 참고 8 】 개인정보 유출에 따른 2차 피해유형 및 대응요령 【 부록 3. 참고 9-1 】 모의훈련 세부 시나리오 A(안) 【 부록 3. 참고 9-2 】 모의훈련 세부 시나리오 B(안) 【 부록 3. 참고 10 】 민원 상담(콜센터) 스크립트(예시) 【 부록 3. 참고 11 】 개인정보 유출 여부 조회 화면 구성(안) 【 부록 3. 참고 12 】 보도자료(양식) (부록 4) 수탁자에 대한 관리 및 감독 절차서 ---- 144 【 서식 4-1 】 입원자 보안서약서 【 서식 4-2 】 출입허가사용계정 신청 및 정품소프트웨어 사용 서약서 【 서식 4-3 】 개인정보 제공 및 활용 동의서 【 서식 4-4 】 개인정보보호서약서 【 서식 4-5 】 개인정보 취급자 관리대장

둘째, “개인정보 내부관리 계획”에 따른 이행 결과에 대해 [표 12]와 같이 적정성 검토를 통해 리스크별 통제방안 도출 및 제도개선을 하였으며 통제 위험 요소를 추가로 발굴하고 후속 조치하여 내부통제 강화에도 노력하였다.

[표 12] “내부관리 계획” 적정성 검토를 통한 리스크별 통제방안 도출

문제점	원인분석	위험도	통제방안 및 조치결과
개인정보파일관리 절차 부재로 관리 미흡 우려	개인정보파일을 운영·관리에 권한을 가진 정보화부서와 보안부서만 관련 업무를 처리하여 전사 차원의 관리체계 확립 필요	高	▶ 개인정보파일 관리 절차서 제정 완료 ▶ 내부관리계획 개정 검토 및 등록 완료
개인정보유출시 피해 확인 긴급조치방안 부재	유출사고 대응 매뉴얼은 존재하나, 사고 발생시 개인정보 유출 여부 조회 화면 부재로 피해구제 신속조치에 어려움 예상	中	▶ ‘개인정보 유출신고 조회’ 화면 구현 완료 ▶ 개인정보 유출사고 대응 매뉴얼 개정 ▶ 내부관리계획 개정 검토 및 등록 완료
접근권한 및 접속기록 관리미흡	정보화 용역사업이 많고 개인정보취급자의 변경이 수시로 발생하고 있어, 개인정보처리시스템 담당자의 실수로 접근권한과 접속기록에 대한 관리가 미흡 가능성 존재	高	▶ 개인정보처리시스템의 접근권한 일체 정비 ▶ 활동 여부를 용역사업 SLA에 반영하고 온라인 증빙 통합관리 ▶ 점검 서식 정비 및 내부관리계획 반영
개인정보 파기 업무 누락	휴면회원(일반회원)은 가입시기가 달라 1년마다 회원별 회원유지 여부를 확인하기 불가능하여 적정시기에 개인정보를 파기하지 못함	高	▶ 개인정보 파기계획 개정 ▶ 내부관리계획 개정 검토 및 등록 완료

셋째, “개인정보 내부관리 계획” 등 개인정보 관련 정책, 제도 및 관리 방법에 대해서는 수시로 인트라넷 게시판, 회의 및 교육 등을 통해 전파하여 임직원 및 전산 관련 용역 수행사의 개인정보보호 의식을 고취하는데 기여하였다.

조치할 사항

□■□■□■■(□■□△▲△장)은 적극적인 업무 자세로 개인정보보호를 위한 내부관리계획 수립, 이행을 통하여 임직원의 개인정보보호 인식 제고에 기여한 관련자에게 타의 모범이 될 수 있도록 격려해주시기 바랍니다. **【모범사례】**

[관련자] ◎◇◆□■ ○◎(◇☆) ◇ ▼ ★

컨설팅감사 결과 모범사례

소 속	직 급	성 명
◎◇◆□■	◇☆	◇▼★

제목: “정보보호 내부관리” 계획 수립, 이행 및 전파 노력

추 천 내 용

□ 충실한 “정보보호 내부관리 계획” 수립

o 기존 「개인정보 보호법」 등에서 제시하고 있는 사항에 대해 나열하는 형식에서 전 직원이 쉽게 이해하고 이행 및 확인할 수 있도록 관련 매뉴얼, 절차서, 주요 점검 일정 및 교육 계획(안) 등을 추가

변경전	변경후
2021년 6월 내부관리계획 총 21 page	2024년 9월 내부관리계획 총 284 page

목 차

1. 총칙 ---------- 1
2. 내부관리계획 수립 및 시행 ---------- 1
3. 개인정보 보호책임자(CPO) 등 지정 ---------- 3
4. 개인정보 보호책임자(CPO) 등 역할 및 책임 ---------- 4
5. 개인정보의 기술적·관리적·물리적 안전조치 ---------- 6
6. 수탁자에 대한 관리 및 감독 ---------- 13
7. 개인정보보호 교육 및 홍보 ---------- 15
8. 가명정보의 안전한 관리 ---------- 16

[부록1] 개인정보처리시스템 접근권한 및 접속기록 관리 절차서
[부록2] 개인정보 목적 외 이용·제3자 제공 절차서
[부록3] 개인정보 침해·유출사고 대응 절차서
[부록4] 개인정보처리시스템 재해재난대비 위기대응 매뉴얼
[부록5] 정보주체 권리보장 절차서
[부록6] 가명정보 처리 절차서

목 차

제·개정 이력 ---------- 1
법적근거 ---------- 7
개인정보 내부관리 계획 개요 ---------- 9
제1장 총칙 ---------- 10
제1조(목적)
제2조(용어 정의)
제3조(안전조치의 적용 원칙)
제3조2 (적용 범위)
제2장 내부 관리계획의 수립 및 시행 ---------- 12
제4조(내부 관리계획의 수립·시행 및 점검)
제5조(내부 관리계획의 공표)
제3장 개인정보 보호책임자(CPO)의 역할 및 책임 ---------- 14
제6조(개인정보 보호책임자의 지정)
제7조(개인정보 보호책임자의 역할 및 책임)
제8조(분야별 개인정보 보호책임자 등의 지정)
제9조(개인정보 취급자의 역할 및 책임)
제4장 개인정보 보호교육 ---------- 16
제10조(개인정보 보호책임자의 교육)
제11조(임직원 및 개인정보 취급자의 교육)
제5장 기술적 안전조치 ---------- 18
제12조(접근 권한의 관리)
제13조(접근 통제)
제14조(개인정보의 암호화)
제15조(접속기록의 보관 및 점검)
제16조(악성프로그램 등 방지)
제17조(관리용 단말기의 안전조치)
제18조(출력·복사시 안전조치)[신규]
제19조(개인정보의 파기)
제6장 관리적 안전조치 ---------- 24
제20조(개인정보 보호조직 구성 및 운영)
제21조(개인정보 유출 사고 대응)
제22조(위험도 분석 및 대응)
제23조(수탁자에 대한 관리 및 감독)
제24조(개인정보보호 홍보)
제7장 물리적 안전조치 ---------- 26
제25조(물리적 안전조치)
제26조(재해 및 재난 대비 안전조치)
제8장 가명정보의 처리 및 보호조치 ---------- 27
제27조(가명정보 및 추가정보 관리책임자 지정)
제28조(가명정보 및 추가정보 별도 분리 보관 및 접근권한 관리)
제29조(가명정보 또는 추가 정보의 안전성확보 조치에 관한 사항)
제30조(가명정보처리자의 교육에 관한 사항)
제31조(가명정보 처리 기록 작성 및 보관에 관한 사항)
제32조(가명정보 등 개인정보 처리방침 공개에 관한 사항)
제33조(가명정보의 재식별 금지에 관한 사항)
제9장 인공지능(AI) 개인정보보호 자율점검 ---------- 29
제34조(기본원칙 준수)
제35조(인공지능(AI) 서비스 개인정보보호 자율점검표 활용)
제10장 영상정보처리 기기 안전성 확보조치 ---------- 30
제36조(영상정보처리기기 설치, 운영 및 개인영상정보 보호)
제37조(고정형 영상정보처리기기 운영·관리 방침)
제38조(고정형 영상정보처리기기 관리책임자의 지정)
제39조(고정형 영상정보처리기기 안내판의 설치)
제40조(고정형 영상정보처리기기 영상정보처리기기 안전성 확보 조치)
제41조(개인영상정보 이용·제3자 제공 등 제한 등)
제42조(개인영상정보의 보관 및 파기)
제43조(개인영상정보의 이용·제3자 제공·파기의 기록 및 관리)
제44조(개인영상정보처리기기 설치, 운영에 대한 점검)
제45조(정보주체의 열람 등 요구)
제46조(개인영상정보 관리대장)
제47조(정보주체 이외의 자의 개인영상정보 보호)
제48조(이동형 개인영상정보처리기기 설치, 운영에 대한 점검)
제11장 공공시스템 운영기관 등의 개인정보 안전성 확보조치 ---- 35
제49조(공공시스템운영기관의 안전조치 기준 적용)
제50조(공공시스템운영기관의 내부 관리계획의 수립·시행)
제51조(공공시스템운영기관의 접근 권한의 관리)
제52조(공공시스템운영기관의 접속기록의 보관 및 점검)
제12장 개인정보 목적 외 이용 및 제3자 제공 안전조치 ---------- 37
제53조(개인정보의 목적 외 이용·제공 제한)
제54조(개인정보를 제공받은 자의 이용·제공 제한)
제13장 정보주체 권리보장 ---------- 39
제55조(정보주체 이외로부터 수집한 개인정보의 수집·출처 등의 통지)
제56조(개인정보 이용·제공 내역의 통지)
제14장 개인정보의 유출, 도난 방지 등을 위한 취약점 점검 ------- 40
제57조(취약점 점검 및 조치)
[붙임 1] 접근권한 관리 기준 강화 ---------- 41
[붙임 2] 2024 월별 개인정보 보호 중점 활동 추진 계획 ---------- 42
[붙임 3] 연간 정보보안·개인정보보호 주요점검 일정 ---------- 44
(부록 1) 2023년 개인정보보호교육 계획안 ---------- 45
【 서식 1-1 】 개인정보보호교육 결과 보고서
【 서식 1-2 】 개인정보보호교육 결과 회의록
(부록 2) 개인정보처리시스템 접근권한 및 접속기록 관리 매뉴얼 ---------- 50
【 서식 2-1 】 DB 개인정보 접근권한 신청(변경)서
【 서식 2-2 】 개인정보 접근기록·접속기록·보유현황·암호화 현황 점검대장
【 서식 2-3 】 개인정보 접속기록 상세 점검내역
【 서식 2-4 】 개인정보 접근권한 관리 자체점검표
(부록 3) 개인정보 침해·유출사고 대응 매뉴얼 ---------- 64
【 부록 3. 서식 1 】개인정보 유출신고서(양식 및 사례)
【 부록 3. 서식 2 】 개인정보 유출신고 조치확인서(양식 및 사례)
【 부록 3. 서식 3 】 개인정보 침해·유출사고 처리보고서(양식)
【 부록 3. 서식 4 】 개인정보 침해사실 신고서
【 부록 3. 참고 1 】 유출 통지방법
【 부록 3. 참고 2 】 표준 개인정보 유출 통지문 (예시)
【 부록 3. 참고 2-1 】 개인정보 유출 통지문"해킹에 의한 유출"
【 부록 3. 참고 2-2 】 개인정보 유출 통지문"내부직원에 의한 유출"
【 부록 3. 참고 2-3 】 개인정보 유출 통지문"용역사(수탁사)에 의한 유출"
【 부록 3. 참고 2-4 】 개인정보 유출 통지문"이벤트시 응역사 부주의에 의한 노출"
【 부록 3. 참고 3 】 개인정보 유출 신고서 (예시)
【 부록 3. 참고 4 】 상황 종료 보고(예시)
【 부록 3. 참고 5 】 개인정보보호 표월 유출신고 절차 및 방법
【 부록 3. 참고 6 】 침해사고 신고 및 경찰 수사 연락처
【 부록 3. 참고 7 】 침해사고 대응 체크리스트
【 부록 3. 참고 8 】 개인정보 유출에 따른 2차 피해유형 및 대응요령
【 부록 3. 참고 9-1 】 모의훈련 세부 시나리오 A(안)
【 부록 3. 참고 9-2 】 모의훈련 세부 시나리오 B(안)
【 부록 3. 참고 10 】 인원 상담(콜센터) 스크립트(예시)
【 부록 3. 참고 11 】 개인정보 유출 여부 조회 화면 구성(안)
【 부록 3. 참고 12 】 보도자료(양식)
(부록 4) 수탁자에 대한 관리 및 감독 절차서 ---------- 144
【 서식 4-1 】 입원자 보안서약서
【 서식 4-2 】 출입허가·사용계정 신청 및 정품소프트웨어 사용 서약서
【 서식 4-3 】 개인정보 제공 및 활용 동의서
【 서식 4-4 】 개인정보보호서약서
【 서식 4-5 】 개인정보 취급자 관리대장

□ "내부관리 계획"의 적정성 검토를 통해 리스크별 통제방안 도출 및 제도개선

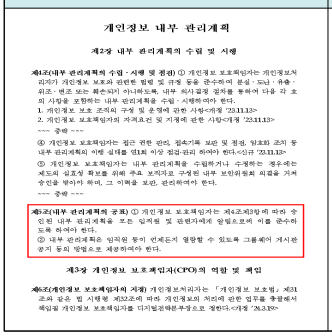
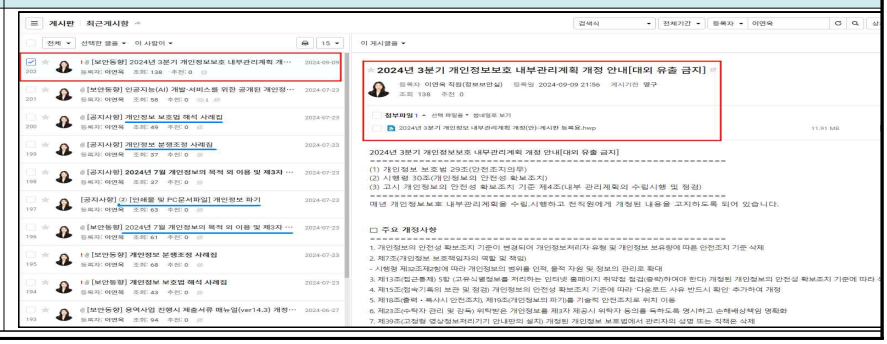
문제점	원인분석	위험도	통제방안 및 조치결과
개인정보파일관리 절차 부재로 관리 미흡 우려	개인정보파일을 운영·관리에 권한을 가진 정보화부서와 보안부서만 관련 업무를 처리하여 전사 차원의 관리체계 확립 필요	高	▶ 개인정보파일 관리 절차서 제정 완료 ▶ 내부관리계획 개정 검토 및 등록 완료
개인정보유출시 피해 확인 긴급조치방안 부재	유출사고 대응 매뉴얼은 존재하나, 사고 발생시 개인정보 유출 여부 조회 화면 부재로 피해구제 신속조치에 어려움 예상	中	▶ '개인정보 유출신고 조회' 화면 구현 완료 ▶ 개인정보 유출사고 대응 매뉴얼 개정 ▶ 내부관리계획 개정 검토 및 등록 완료
접근권한 및 접속기록 관리미흡	정보화 용역사업이 많고 개인정보취급자의 변경이 수시로 발생하고 있어, 개인정보처리시스템 담당자의 실수로 접근권한과 접속기록에 대한 관리가 미흡 가능성 존재	高	▶ 개인정보처리시스템의 접근권한 일체 정비 ▶ 활동 여부를 용역사업 SLA에 반영하고 온라인 증빙 통합관리 ▶ 점검 서식 정비 및 내부관리계획 반영
개인정보 파기 업무 누락	휴면회원(일반회원)은 가입시기가 달라 1년마다 회원별 회원유지 여부를 확인하기 불가능하여 적정시기에 개인정보를 파기하지 못함	高	▶ 개인정보 파기계획 개정 ▶ 내부관리계획 개정 검토 및 등록 완료

□ 개인정보보호 활동 전개시, 통제위험 요소를 추가로 발굴하고 추가조치 시행

문제점	원인분석	위험도	통제방안 및 조치결과
용역사업 보안관리 미흡 또는 업무누락	정보화 용역사업이 많고 개인정보취급자 변경이 수시로 발생, 사업담당자나 개인정보보호담당자의 업무 누락 리스크 존재	高	▶ 정보화사업 보안서류 제출 일원화 ▶ 전사 정보화사업 개인정보 보호관리 체계 마련
개인정보 영향평가 결과 등록 누락	개인정보 영향평가와 조치이행결과 확인 업무를 수행했음에도 불구하고, 담당자 변경이나 실수로 개인정보포털에 등록누락 위험존재	中	▶ 전사 용역사에 영향평가 제도 특별 안내 ▶ 보안위원회에 영향평가 현황 보고
일부 임직원의 교육 미이수	일부 직원의 경우 무관심과 무★□으로 필수 보안교육을 이수하지 않는 사례가 발생하여 보안사고의 위험이 증대	中	▶ 전직원 100% 이수할 때까지 교육 실시 ▶ 교육 미이수시 벌점 부여 등 의무부과 강화 ▶ 사고 사례 중심 교육으로 전달력 높임

□ **(전직원 전파) 내부관리계획 '제5조(공표)'**에 따라 임직원이 언제든지 열람할 수 있도록 **그룹웨어 게시판에 공지하고, 개보위 등 주요 정보도 실시간 공유** 중

※ 수시 전파 사항 : 개인정보 보호법 해석 사례집, 분쟁조정 사례집, 개인정보 파기 등

내부관리계획 전파 지침	게시판 내부관리계획 전파
	

o (정보화부서 전파) 내부관리계획 중 위수탁자 관리 감독에 관한 사항은 별도의 **위수탁 관리 표준업무 매뉴얼을 제작하여 정보화부서 개인정보취급자 모두에게 교육·안내 실시**

위수탁사업 표준 관리감독 안내서 제작·배포		외부전문가 초빙 교육 실시
version. 14.4 개인정보처리위탁사업 관리 및 감독 안내서 2024년 7월 KEIT 한국산업기술기획평가원	목 차 - 용역사 제출 필수 서류 - 1. [서식 3] 개인정보처리위탁 계약서(개약체결) ····· 2 2. [서식 5] 보안 및 개인정보보호교육(사업착수+인력변경시) ····· 4 3. [서식 10] 개인정보보호 서약서(사업착수+인력변경시) ····· 6 4. [서식 11] 개인정보 취급자 관리대장(사업착수+인력변경시) ····· 7 5. [서식 12] 수탁업체 개인정보 관리 실태 자체 점검표(사업착수) ····· 8 6. [서식 13] DB 개인정보 접근권한 신청서(DB접근권한 신청시) 해당시 ····· 9 7. [서식 17] 자료관리대장(사업수행 중 자료인계 인수시) ····· 10 8. [서식 23] 퇴원자 보안서약서(사업종료시) ····· 11 9. [서식 24] 용역관련자료 삭제 확인 및 보안확약서(사업종료시) ····· 12 - KEIT 개인정보처리시스템(DBA) 담당자 필수 점검 서류 - 10. [서식 14] 개인정보 접근기록,접속기록,보유현황,암호화 현황 점검표 ····· 14 11. [서식 15] 개인정보 접속기록 상세 점검표 ····· 15 12. [서식 16] 개인정보 접근권한 관리 자체점검표 ····· 16 - KEIT 사업담당자 필수 서류 (해당시) - 13. [서식 19] 개인정보파일 관리대장(파일 신규 구축·변경 시+별도 안내시) 18 14. [서식 21] 개인정보의 목적외 이용 및 제3자 제공 대장 및 공고문(제3자 제공 시) 19 15. [서식 26] 개인정보 영향평가 관련 표준서식 (영향평가 수행 시) ····· 21 * 영향평가 시작 [26-1] / 종료[26-2] / 종료 후 10개월 이내[26-3, 26-4]	개인정보처리시스템 취급자 대상 개인정보보호 및 정보보안 전문교육 결과보고서 - 2024 9. 13(금) 디지털혁신본부 정보보안실 - □ 교육 목적 o 개인정보 보호의 중요성에 대한 인식 제고 및 의식 전환 o 안전한 개인정보의 취급을 보장하는 개인정보 보호 대책의 필요성 o 개인정보처리시스템 취급자(IT 부서원 및 PM)을 대상으로 개인정보 보호의 중요성과 관련 규정·지침·절차를 이해하고 실제 업무에 적용할 수 있도록 교육 추진 □ 교육 개요 o 교 육 명 : 2024년 개인정보 안전성 확보조치 o 교육대상 : 개인정보처리시스템 취급자(IT 부서원 및 PM) o 교육일시 : 2024년 9월 10일(화) 13:00~14:00 o 교육장소 : 대전 상상가 o 교육강사 : 포유시큐리티 옥은택 대표 o 교육내용 : ① (개인정보보호) 개인정보 보호법, 개인정보의 안전성 확보조치 □ 교육결과 대상: 수탁사 PM 및 실무자 28명 / 디지털전략본부 전직원 25명 일자: 2024년 9월 10일(화) 13:00~14:00 장소: 대전 상상가 (대전 서구 둔산중로 14번길 15-8 2층) 교육내용: 개인정보 안전성 확보조치 강사: 포유시큐리티 옥은택 대표 이수율: 수탁사 27명 / 89%; 디지털전략본부 23명 / 92%

□ 관리 제도와 정책을 「전직원 공통 전파」하고, 수탁사와 정보화부서는 「특별 전파」 실시

o (용역사 전파) CPO(위원장) 중심의 정보화부서-용역사 협의체에 내부관리 정책기준 공유·전파

정보화부서-용역사 전사 협의회 안건 안내(처리방침, 파기, 위수탁 산출물 등)		관리실태 자체점검표 및 점검기준 배포
안내안건 1 개인정보 처리 위탁 용역사업 필수 보안활동 산출물 안내 별첨 참고 - 용역사 제출 필수 서류 - 1. [서식 3] 개인정보처리위탁 표준 계약서(개약체결) ····· 2 2. [서식 10] 개인정보보호서약서(사업착수+인력변경) ····· 4 3. [서식 11] 개인정보 취급자(수탁자 포함) 관리대장(사업착수+인력변경) ····· 5 4. [서식 12] 수탁업체 개인정보 관리 실태 점검표(사업시작 후 3개월 이내) ····· 6 5. [서식 13] DB개인정보 접근권한 신청서(DB접근권한 신청시) 해당시 ····· 7 6. [서식 17] 자료관리대장(사업수행 중 자료인계 인수시) ····· 8 7. [서식 23] 퇴원자 보안서약서(사업종료) ····· 9 8. [서식 24] 용역관련자료 삭제 확인 및 보안확약서(사업종료) ····· 10 - KEIT 개인정보처리시스템(DBA) 담당자 필수 점검 서류 - 9. [서식 14] 개인정보 접근기록,접속기록,보유현황,암호화 현황 점검표양 ····· 12 10. [서식 15] 개인정보 접속기록 상세 점검표역 ····· 13 11. [서식 16] 개인정보 접근권한 관리 자체점검표 ····· 14 - KEIT 사업담당자 필수 서류 (해당시) - 12. [서식 19] 개인정보파일 관리대장(파일 신규 구축·변경 시 + 별도 안내시) ····· 16 13. [서식 21] 개인정보의 제3자 제공 대장 및 공고문(제3자 제공 시) ····· 17 14. [서식 26] 개인정보 영향평가 관련 표준서식 (영향평가 수행 시) ····· 19 * 영향평가 시작단계 [26-1] / 종료단계[26-2] / 종료 후 10개월 이내[26-3, 26-4]		version. 14.4 수탁업체 개인정보 관리실태 자체점검표 2024년 7월

일련번호	3	감사자	▽◆◎	공개(○), 비공개(　)	
신분상 조치인원	-	재정상 조치방법	-	재정상 조치금액	-
수감부서 (처리할 부서)	□■□■□■■ (◆□■☆★☆▼▲□)	처분요구일	2024.12.	회신 기한일	-

모 범 사 례

제　　목　**범부처 연구비통합관리시스템(RCMS) 사용자 개인정보 보호 등에 기여**

관 계 부 서　**□■□■□■■(◆□■☆★☆▼▲□)**

조 치 부 서　**□■□■□■■(◆□■☆★☆▼▲□)**

내　　용

한국산업기술기획평가원(이라 '기획평가원'라 한다)은 국가연구개발사업의 관리에 있어 연구개발비 집행의 투명성과 연구자의 편의성을 제고하기 위하여 범부처 연구비통합관리시스템(Real Cash Management System, 이하 'RCMS'라 한다)을 구축하여 운영하고 있으며 '24년 11월 현재 산업통상자원부, 해양수산부, 경기도 등 7개 부처, 1개 지자체 소속 25개 기관이 RCMS를 이용하고 있다.

한편, 2021년부터 국가연구개발사업은 「국가연구개발혁신법」의 적용을 받고 있는데 부처간의 법·규정에 대한 해석 차이와 관련 규정의 적용이 미흡하여 RCMS를 사용하는 전문기관 담당자, 회계법인 담당자, 수행자 등 이해관계자들에게 연구 행정의 어려움이 발생되었다.

이를 개선하기 위하여 ◆□■☆★☆▼▲□☆□△ ★□은 적극적인

업무 자세로 「국가연구개발혁신법」 및 연구수행자의 요구에 맞추어 RCMS 기능을 개선하였다.

예를 들면 과기부 고시「국가연구개발정보처리기준」에 의거 연구활동비 부가 정보를 내부 회계시스템과 RCMS에 이중으로 등록해야 하는데 국가연구자번호를 필수로 하되 성명, 소속 등 개인 민감 정보는 보수적으로 수집될 수 있도록 기능을 개선하여 연구편의를 도모함과 동시에 개인정보를 보호할 수 있도록 하였다.

또한 이전에는 과학기술정보통신부와 산업통상자원부의 연구개발비 지급방식 및 정산 방식이 달라서 정산업무를 수행하는 실무자들이 느꼈던 불편한 점을 해소(예:연차정산→단계정산)하고 직접비 이월금을 세목 간 전용이 불가능하였던 것을 전용 가능 기능을 추가하여 연구수행자의 편의성을 높이는 등 「국가연구개발혁신법」에 맞추어 일원화함으로써 이해관계자들의 혼선을 최소화하도록 노력하였다.

이는 RCMS를 구축·운영하는 전담하는 기획평가원이 연구수행자의 다양한 민원을 신속히 처리한 적극적인 행정이라 할 수 있다.

조치할 사항

□■□■□■■장(◆□■☆★☆▼▲□장)은 적극적인 업무자세로 범부처 연구비통합관리시스템(RCMS)를 「국가연구개발혁신법」및 연구수행자의 요구에 맞추어 개선한 관련자에게 타의 모범이 될 수 있도록 격려해 주시기 바랍니다. **【모범사례】**

[관련자] ◆□■☆★☆▼▲□ ▲◎(★□) ☆ □ △

컨설팅감사 결과 모범사례

소 속	직 급	성 명
◆□■☆★☆▼▲□	★□	☆□△

제목: 범부처 연구비통합관리시스템 개선 관련 적극행정 노력

추 천 내 용

□ 연구개발혁신법·규정에 대한 해석 차이로 인해 연구 행정업무 혼란 가중

○ '21년부터 국가 R&D사업은 『연구개발혁신법』으로 관리 중이나 **애매한 법·규정의 해석 차이**와 **규정 전산화의 미비**로 **연구 행정의 어려움**이 발생

○ 이러한 이해관계자들간의 **연구 행정의 불편함을 해소**하고 **추가적인 민원의 발생을 방지**하기 위하여 시스템 개선을 위한 방안을 기획

□ 연구활동비 부가정보 수집을 위한 연구개발기관 사용자 화면 개선

○ 과기부 고시 『국가연구개발정보처리기준』에 의거 연구활동비 항목 중 '출장비, 회의비, 전문가 활용비'의 세부 항목 수집 근거에 따라

- 연구비 관리 실무자들은 연구활동비 부가정보를 내부 회계시스템과 RCMS 시스템에 이중으로 등록해야 하는 상황에 직면하였으나

○ 연구활동비 세부 항목을 쉽게 등록할 수 있도록 기능 개선하여 연구 행정 편의를 도모하였고 과제 연구에 집중할 수 있는 환경을 제공

- 수집 항목 중 국가연구자번호를 필수로 하되 성명, 소속 등 개인 민감 정보는 보수적인 수집 정책을 적용하여 현시점 개인정보보호 정책을 지향

□ 사업비 재원(정부·민간부담금)별 정산금 비율 산정에 대한 해석

○ 혁신법 매뉴얼 내에 "정부 지원금 지분 산출 대상 연구개발비는... **해당 단계(단계 구분이 없으면 전체 연구개발기간)의 연구개발비**를 말함" 이라 명시

- 연구비통합관리시스템(RCMS·Ezbaro)을 혼용하여 정산 업무를 수행하는 정산실무자들은 건별·일괄 지급 방식의 차이에 따른 업무혼선이 발생

○ 건별지급 방식인 RCMS는 **혁신법 이전 연차정산 시 당해 사업비 비율***을 적용하였으나 **혁신법 기준에 맞추어 단계 사업비 비율로 변경 적용**

* 일괄지급 방식인 Ezbaro와 달리 실시간으로 연차별 집행 내역을 관리하고 있는 RCMS는 연차 사업비 비율로 더 정확하게 산정하고 있었으나 혁신법 기준에 맞게 단계 사업비 비율로 변경

□ 연구개발 직접비 이월금을 세목 간 전용이 가능하도록 개선

○ 혁신법 매뉴얼 내에 "이월된 연구개발비는 동일 항목으로 사용하여야 하되, **직접비 내 항목 간 전용이 가능**함." 을 명시하고 있으나

- '21.9월 통합연구지원시스템(IRIS)의 개선요구(KISTEP)로 단계 내 이월금 관리 기능은 추가하였으나 세목 간 이동은 불가하였음(IRIS측 요구사항)

○ 혁신법 시행 이후 **동일 세목으로만 이월***해서 사용하던 방식에서 벗어나 **이월금의 세목 간 전용이 가능하게 기능을 개선**하여 업무행정 편의 제공

* IRIS 측 의견에 따라 이월금에 대한 세목 간 전용을 불가토록 하였고, 전용이 필요할 시 전문기관으로부터 공문을 접수받아 수기로 데이터를 보정하여 적용

□ **R&D 이해관계자들의 연구비 행정업무 개선을 위한 적극적인 업무추진**

○ 혁신법에 근거하여 전 부처의 연구비 관리 행정 기준에 맞추어 시스템을 개선하였고 적극적이고 헌신적인 업무 태도를 감안하여 모범사례로 추천함